

The Practitioner's Blueprint for Secure AI

By John M. Willis, Quantum Powered Security, Inc.



August 2025

Copyright and License

Copyright © 2025 John M. Willis and Quantum Powered Security, Inc.

This manuscript is licensed under the Creative Commons Attribution 4.0 International License (CC BY 4.0). You are free to share and adapt this work for any purpose, including commercial use, provided appropriate attribution is given.

License: <https://creativecommons.org/licenses/by/4.0/>

Patent Notice

The concepts, architectures, and reference designs presented in this work are intended to encourage adoption, adaptation, and further innovation. Readers are encouraged to tailor PBSAI to their own environments, products, and services. Novel implementations, extensions, and improvements developed by others may be eligible for intellectual property protection under applicable patent laws.

The authors likewise reserve all rights to pursue patent protection for their own inventions, implementations, improvements, and future developments related to PBSAI. Certain aspects of this work are the subject of pending patent applications. Except as expressly stated by applicable law, no patent rights are granted or implied by this publication or its CC BY 4.0 license.

Volume 2: The Multi-Agent AI Defensive Cybersecurity Ecosystem

Domain I – Security Architecture & System Engineering

Table of Contents

Domain I - Security Architecture & Systems Engineering (SASE)	4
I1. Architecture Advisor Agent	4
Agent Blueprint [Informative]	4
Technical Implementation Details (I1) [Informative]	13
MCP-Native Protocol Specification (I1) [Normative]	15
I2. SSE Process Agent	16
Agent Blueprint [Informative]	16
Technical Implementation Details (I2) [Informative]	28
MCP-Native Protocol Specification (I2) [Normative]	30
I3. Crypto Architecture Agent	31
Agent Blueprint [Informative]	31
Technical Implementation Details (I3) [Informative]	40
MCP-Native Protocol Specification (I3) [Normative]	42
I4. Protocol Compliance Agent	43
Agent Blueprint [Informative]	43
Technical Implementation Details (I4) [Informative]	53
MCP-Native Protocol Specification (I4) [Normative]	55
I5. Pattern Management Agent	56
Agent Blueprint [Informative]	56
Technical Implementation Details (I5) [Informative]	67
MCP-Native Protocol Specification (I5) [Normative]	69
I6. DevSecOps Pipeline Agent	70
Agent Blueprint [Informative]	70
Technical Implementation Details (I6) [Informative]	85
MCP-Native Protocol Specification (I6) [Normative]	88

Domain I - Security Architecture & Systems Engineering (SASE)

I1. Architecture Advisor Agent

Agent Blueprint [Informative]

Purpose: Review proposed solution/system designs for security impacts; identify gaps, risks, and control mappings; recommend mitigations.

Operational Narrative [Informative]

Inputs used (authoritative sources):

- **Diagram Artifacts** (Object Storage / Git): PlantUML, draw.io JSON, SysML/XMI exports; component names, trust boundaries, protocols, data stores, identity providers.
- **Requirements Specifications** (Git/Docs/ReqIF): security/system requirements, acceptance criteria, version/timestamp, control references.

Model training / knowledge (what the LLM relies on):

- Style and rubric prompt pack (architecture review checklist; patterns/anti-patterns aligned to NIST 800-160, 800-53, CIS, ISO/IEC 27002).
- RAG sources (architecture pattern library, prior review decisions, control catalog with mappings; do not train on regulated evidence—use evidence_refs).
- Guardrails (read-only for source repos unless explicitly scoped to comment endpoints; scoped tokens; allowlist of diagram/reqs paths).

Decisions it makes (deterministic + model-assisted):

- **Gap detection:** missing controls at trust boundaries (e.g., ingress TLS 1.3, mutual auth, egress filtering).
- **Risk rating:** compute arch_risk_score and severity per component and end-to-end flow.
- **Control mapping:** link findings to 800-53 families (SC, AC, IA, SA, SI), CIS v8, ISO 27002.
- **Mitigation recommendations:** specific, testable actions with acceptance criteria.

- **Escalation:** route high-risk findings to tickets and block merge when constraints include "no_prod_without_arch_review".

Routing / where outputs go:

- **ArchReviewFindings** → event bus (Kafka/AMQP) and/or REST endpoint; optionally attach to design PR thread.
- **PR comments** → design repos with inline references to diagram nodes/lines.
- **Tickets** → issue tracker (e.g., Jira/ServiceNow) for required fixes, linked to components and controls.

Automation scope vs. manual/HITL:

- Fully automated: diagram parsing, static checks for boundary controls, default control mappings, draft recommendations.
- **HITL required:** architecture risk trade-offs (e.g., compensating controls), acceptance of residual high risk, exceptions/waivers.
- Manual outside agent: selection/approval of novel patterns, non-functional trade-offs affecting cost/performance outside security remit.

Security Domain: Security Architecture & Systems Engineering (SASE)

Inputs (native protocols consumed) [Informative]

1. **Diagram Artifacts (Object Storage / Git)** — parse PlantUML / draw.io JSON / SysML to extract components, links, and trust boundaries.
2. **Requirements Specifications (Git/Docs/ReqIF)** — ingest security/system requirements and control references.

Example: Consumed Protocol — Diagram Artifacts [Informative]

Native payload (PlantUML)

```
@startuml
```

```
skinparam componentStyle rectangle
```

```
package "Payments" {
```

```
    [API Gateway] -down-> [Auth Service]
```

```
    [API Gateway] -right-> [Orders Service]
```

```
}
```

[Auth Service] ..> (Okta) : OIDC

[Orders Service] --> (PostgreSQL) : TLS

cloud "Internet" as net

net --> [API Gateway] : HTTPS

@enduml

MCP-wrapped payload

```
{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-i1-arch-1111-2222-3333-4444",
    "thread_id": "uuid-design-review-payments-v1",
    "task_id": "uuid-a1b2-c3d4-e5f6-7788",
    "role": "ArchitectureAdvisorAgent",
    "intent": "assess",
    "policy_refs": ["SC-7", "SC-8", "IA-2", "SA-8"],
    "decision_basis": {
      "evidence_refs":
["uri://git/arch/payments/diagrams/payments.puml@commit:b17a53f"],
      "confidence": 0.92,
      "explanation_ref": "uri://kb/arch/patterns/zero-trust-edge"
    },
    "provenance": {
      "producer_spiffe": "spiffe://enterprise/arch/architecture-advisor-agent",
      "signing_kid": "kid-arch-i1-01",
      "attestation_ref": "uri://slsa/attestations/arch-advisor@sha256:puml01"
    },
    "classification": "C2",
```

```

    "legal_hold": false
  },
  "native_payload": "@startuml ... @enduml"
}

```

Example: Consumed Protocol — Requirements Specifications [Informative]
Native payload (ReqIF-like JSON)

```

{
  "doc_id": "REQ-PAY-SEC-001",
  "title": "Payments Security Requirements v1.2",
  "requirements": [
    {
      "id": "SEC-NET-01",
      "text": "All external connections must terminate TLS 1.3 at the edge.",
      "controls": ["SC-13", "SC-8"]
    },
    {
      "id": "SEC-AUTH-02",
      "text": "All user traffic must be authenticated via OIDC with MFA.",
      "controls": ["IA-2", "AC-7"]
    },
    {
      "id": "SEC-DATA-03",
      "text": "Encrypt data at rest using FIPS-validated modules.",
      "controls": ["SC-12", "SC-28"]
    }
  ],
  "version": "1.2",
  "owner": "security.architecture",
  "updated": "2025-08-15T12:30:00Z"
}

```

MCP-wrapped payload

```

{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-i1-arch-1111-2222-3333-4444",
    "thread_id": "uuid-reqs-REQ-PAY-SEC-001",
    "task_id": "uuid-99aa-bbcc-ddee-ff00",
  }
}

```

```

"role": "ArchitectureAdvisorAgent",
"intent": "assess",
"policy_refs": ["SC-13", "SC-8", "IA-2", "AC-7", "SC-12", "SC-28"],
"decision_basis": {
  "evidence_refs": ["uri://git/requirements/REQ-PAY-SEC-001.json@v1.2"],
  "confidence": 0.95,
  "explanation_ref": "uri://kb/arch/reqs-to-controls-mapping"
},
"provenance": {
  "producer_spiffe": "spiffe://enterprise/arch/architecture-advisor-agent",
  "signing_kid": "kid-req-i1-02",
  "attestation_ref": "uri://slsa/attestations/arch-advisor@sha256:req02"
},
"classification": "C2",
"legal_hold": false
},
"native_payload": { "...": "..." }
}

```

Outputs (native) [Informative]

- **ArchReviewFindings** with severities, control mappings, and recommendations.
- **Optional:** PR comments to design repos; tickets for required fixes.

MCP context (required) [Informative]

mission_id; role="ArchitectureAdvisorAgent"; intent="assess"; policy_refs (e.g., 800-53 SC-7, AC-3, SA-8); provenance (SPIFFE ID, signing KID, attestation)

MCP context (optional) [Informative]

classification (usually C2); decision_basis (evidence_refs, confidence, explanation_ref); constraints (e.g., "no_prod_without_arch_review"); legal_hold

Enforcement note [Informative]

Release/merge gates and PEPs must enforce **constraints** such as "no_prod_without_arch_review" and block promotion when **High** or **Critical** unresolved findings exist.

NIST SP 800-160v2 linkage [Informative]

Architecture-centric, evidence-driven security engineering (concept, requirements, and architecture evaluation).

Automation feasibility [Informative]

Partial–High: static checks and pattern matching are automatable; risk trade-offs and exceptions require HITL.

Output Contracts (merged) [Informative]

OC-1: ArchReviewFindings [Informative]

- **Producer(s):** I1
- **Topic/Path:** sec.arch.findings (Kafka/AMQP) or POST /arch/reviews/{mission_id}/findings
- **Schema/Format:** ArchReviewFindings@1.0 (findings[], severity, arch_risk_score, control_mappings[], recommendations[], component_refs[], evidence_refs[], decision_rationale_url)
- **Classification:** C2
- **Delivery:** at-least-once
- **Ordering:** per-mission_id
- **Idempotency-Key:** sha256(mission_id, diagram_digest, reqs_version)
- **Ack/Nack:** 202 Accepted or 201 Created; NACK = 4xx/5xx
- **Timeouts/Retry:** ack<=60s; exp-backoff<=5x; on repeated failure create ticket and flag HITL
- **Side-Effects:** append immutable review record; update architecture review index; link to PR thread if present
- **HITL Token:** required to downgrade Critical or accept exception

- **Observability:** trace_id, mission_id, policy_refs, evidence_refs, decision_basis.*, classification_label, provenance.attestation
- **Retention/TTL:** 7 years (or per architecture governance policy)

Schema Capsule (OC-1) [Normative]

Requirement Level: Required

Condition: Always

schema_id=ArchReviewFindings@1.0 | json_schema_uri=uri://schema/arch-review-findings-1.0.json | sha256= | producers=l1 | consumers=DesignPortal-01, PRBot-01, GRC-01 | accepts=1.0–1.x

Conformance: This capsule and the corresponding MCP schema define testable requirements.

OC-2: DesignPRComment [Informative]

- **Producer(s):** l1
- **Topic/Path:** POST /repos/{repo}/pulls/{pr}/comments or sec.arch.pr_comments
- **Schema/Format:** DesignPRComment@1.0 (pr_id, file_path|diagram_node_ref, line_or_anchor, comment_text, severity, control_refs[])
- **Classification:** C1 (content sanitized)
- **Delivery:** at-least-once
- **Ordering:** per-pr_id
- **Idempotency-Key:** sha256(pr_id, diagram_node_ref, comment_text_hash)
- **Ack/Nack:** 201 Created; NACK on 4xx/5xx
- **Timeouts/Retry:** ack<=30s; exp-backoff<=5x
- **Side-Effects:** link comment to finding_id(s) and mission_id; update PR checklist
- **HITL Token:** none (comments are advisory; blocking handled by gates)
- **Observability:** trace_id, mission_id, pr_id, finding_ids[]
- **Retention/TTL:** per repo policy

Schema Capsule (OC-2) [Normative]

Requirement Level: Conditionally Required

Condition: When design repositories support inline PR comments or when org policy requires comments for visibility

schema_id=DesignPRComment@1.0 | json_schema_uri=uri://schema/design-pr-comment-1.0.json | sha256= | producers=l1 | consumers=PRBot-01 | accepts=1.0–1.x
Conformance: Normative when condition is met.

OC-3: RemediationTicket [Informative, optional]

- **Producer(s):** l1
- **Topic/Path:** sec.arch.tickets or /tickets (Jira/ServiceNow)
- **Schema/Format:** RemediationTicket@1.0 (ticket_id, mission_id, component_ref, severity, due_by, required_controls[], acceptance_criteria, links=findings[])
- **Classification:** C2
- **Delivery/Ordering:** at-least-once; per-ticket_id
- **Idempotency-Key:** sha256(mission_id, component_ref, finding_hash)
- **Ack/Nack:** 201 Created; retry/backoff
- **Side-Effects:** attach to sprint/epic; create waiver workflow if due_by exceeded
- **HITL Token:** required to close ticket with residual risk High or Critical
- **Observability:** trace_id, mission_id, ticket_url, finding_ids[]
- **Retention/TTL:** per IRM policy (≥ 1 year)

Schema Capsule (OC-3) [Normative]

Requirement Level: Conditionally Required

Condition: When org mandates tracked remediation or when any finding severity $\geq$ High

schema_id=RemediationTicket@1.0 | json_schema_uri=uri://schema/remediation-ticket-1.0.json | sha256= | producers=l1 | consumers=Jira-01, SNOW-01 | accepts=1.0–1.x

Conformance: Normative when condition is met.

State machine (concise) [Informative]

states = { idle, ingesting_diagrams, parsing_requirements, analyzing, drafting_findings, issuing_recommendations, awaiting_HITL, failed, closed }

transition(idle -> ingesting_diagrams) when new diagram artifact or update detected

transition(ingesting_diagrams -> parsing_requirements) when diagram digest computed

transition(parsing_requirements -> analyzing) when reqs version resolved

transition(analyzing -> drafting_findings) when checks complete

transition(drafting_findings -> issuing_recommendations) when severity computed
 transition(issuing_recommendations -> awaiting_HITL) when any finding severity >= High or exception requested
 transition(* -> failed) on schema/timeout/auth errors
 timeout(issuing_recommendations, 60s) -> failed; retry <= 5 with exp backoff
 idempotency_key = sha256(mission_id, diagram_digest, reqs_version)

Output Contracts Summary [Normative]

Output Contract	Requirement Level	Trigger Condition	Business Impact
OC-1 ArchReviewFindings	Required	Always	Central review record, risk posture
OC-2 DesignPRComment	Conditionally Required	PR platform supports comments or policy requires visibility	In-context developer guidance
OC-3 RemediationTicket	Conditionally Required	Any finding severity >= High or tracked remediation required	Ensures closure and accountability

Requirement Level Definitions:

- **Required:** Must be implemented for conformant deployment
- **Conditionally Required:** Must be implemented when trigger condition is met
- **Optional:** May be implemented for enhanced functionality

Policies and HITL gates [Informative]

- **policy_refs:** SC-7, SC-8, SC-12, SC-13, SC-28, AC-3, IA-2, SA-8 (+ org-specific standards)
- **HITL required:** acceptance of residual High/Critical risk; waivers; novel pattern approvals
- **Automatic HITL escalation triggers:** model_confidence < theta_low; disagreement_score >= 0.5 between pattern rules and requirements; exception_requested = true

- **Manual outside agent:** architecture exceptions requiring executive risk acceptance

SLOs and KPIs [Informative]

- FindingsEmit_p95 <= 60 s from diagram+reqs ingestion
- FalsePositiveRate_30d <= 10 percent
- HighRiskMTTR_30d <= 14 days
- WaiverComplianceRate_90d >= 95 percent

Outputs index [Informative]

[OC-1 ArchReviewFindings], [OC-2 DesignPRComment], [OC-3 RemediationTicket]

Technical Implementation Details (I1) [Informative]

Model and training profile [Informative]

model_id=arch-review-text-model; temperature=0.1; max_tokens_out=900
 prompt_pack_id=arch-review-v1 (checklists, patterns, anti-patterns, few-shots)
 RAG: sources={pattern library, prior reviews, control catalog, protocol matrix};
 max_docs=10; min_similarity=0.78; citations required
 fine_tuning/adapters: none initially; evaluate on precision/recall of findings and mapping accuracy
 guardrails: read-only on source repos unless comment scope enabled; strict schema validation for produced events

Memory and state [Informative]

working_memory.max_tokens=4k; eviction=recency_then_importance
 episodic_memory: per mission_id journal (artifacts, hashes, reqs versions, emitted findings), ttl=365d
 semantic_memory: namespaces=["arch-patterns","prior-reviews","controls"];
 embeddings=text-embedding-sec-v1; k=10
 durable_state_store: event-sourced journal; snapshot on each findings emission
 consistency: at-least-once (events); exactly-once per idempotency_key for OC-1
 idempotency: per Output Contracts

Decision and routing logic [Informative]

- **Boundary checks:** ensure TLS 1.3 at edge; mutual TLS for service-to-service where required; IDP integration on auth flows.

- **Data protection:** encryption at rest for stateful stores; key management references.
- **Egress control:** deny-by-default and allowlist to third parties.
- **Risk scoring:**

$$\text{arch_risk_score} = 0.35\text{boundary_control_gaps} + 0.25\text{data_protection_gaps} + 0.20\text{authz_authn_gaps} + 0.10\text{exposure_surface} + 0.10*\text{unknowns_weight}$$

$$\text{severity} = \text{map_score_to_severity}(\text{arch_risk_score}, \text{business_criticality}, \text{compensating_controls})$$
- **Routing:** if severity >= High → emit OC-1 + OC-3; else emit OC-1 (+ OC-2 for developer visibility).

Model Risk Management [Informative]

continuous_validation: daily; eval_suite=[goldens for known patterns, adversarial diagrams, noisy reqs]
 thresholds: eval_pass_rate >= 99.0 percent → auto_HITL if below
 red_team_cycle: monthly ATT&CK-informed architecture probes
 rollback_policy: eval_drop >= 1.5 percentage points for 48 h → revert model_id; notify owners

Transparency and Audit Trail (Approver/Auditor UX) [Informative]

decision_rationale_template: finding_id, control_refs, why-it-matters, evidence_refs, recommended_fix
 UI/API: expose classification_label, provenance.attestation, decision_rationale_url
 audit_log_format: JSONL; retention per classification/legal_hold

Incident Response Integration [Informative]

On post-incident reviews, ingest incident lessons-learned as patterns; back-propagate to checklists and RAG corpus (governance-reviewed).

Change Impact Assessment [Informative]

If requirements updated → recompute arch_risk_score_delta; attach to OC-1 as change_impact block.

Stakeholder Feedback Loop [Informative]

Capture ack/reject on each finding; labels={useful|noise|duplicate}; feed governance-reviewed improvements to prompt_pack.

Data Sovereignty and Legal Hold [Informative]

classification default C2; respect legal_hold true to freeze deletions.

Interfaces (links only) [Informative]

Consumes: Diagram Artifacts; Requirements Specifications

Produces: OC-1 ArchReviewFindings; OC-2 DesignPRComment; OC-3 RemediationTicket

Safety and abuse prevention [Informative]

kill_switch on anomalous emission rate or schema validation failures; rate-limits on comment/ticket creation; deny write outside scoped repos/trackers.

Testing and validation [Informative]

contract tests for OC-1..OC-3; offline replay of historical diagrams/reqs; seeded edge cases (missing boundary, third-party egress, shared DB).

Deployment and lifecycle [Informative]

HPA on queue depth; canary model rollout; SBOM and SLSA attestations; sign all outputs.

References / Standards [Informative]

NIST SP 800-160 Vol. 2; NIST SP 800-53 Rev. 5 (SC, AC, IA, SA, SI); NIST SP 800-207; ISO/IEC 27002:2022; CIS Controls v8; MITRE ATT&CK/D3FEND; SAE architecture guidance.

MCP-Native Protocol Specification (I1) [Normative]

(Canonical schemas and validation live here; keep example payloads synchronized with the Agent Blueprint.)

- **Native Protocol(s) Consumed:** Diagram Artifacts (PlantUML/draw.io/SysML); Requirements Specifications (Git/Docs/ReqIF)
- **Native Protocol(s) Produced:** ArchReviewFindings (events/REST); DesignPRComment (PR APIs); RemediationTicket (ticketing APIs)
- **MCP Context Fields:**
 - **Required:** mission_id; role="ArchitectureAdvisorAgent"; intent="assess"; policy_refs=[...] ; provenance.attestation (SPIFFE + KID).

- **Optional:** classification (C2); decision_basis (evidence_refs, confidence, explanation_ref); constraints (e.g., "no_prod_without_arch_review"); legal_hold.
- **Enforcement Note:** PEPs and release gates MUST verify no unresolved High/Critical findings when constraint "no_prod_without_arch_review" is active.
- **Versioning and compatibility; producers/consumers registry:** authoritative in schema registry; see Schema Capsules for accepted ranges/EOL.
- **Example payloads:** native and MCP-wrapped examples above are authoritative.
- **Transparency hooks:** classification_label, provenance.attestation, decision_rationale_url available to downstream UIs/APIs.

Conformance: This section is **[Normative]** and, together with each **Schema Capsule**, defines testable requirements.

I2. SSE Process Agent

Agent Blueprint [Informative]

Purpose: Enforce Security Systems Engineering (SSE) tasks per NIST SP 800-160 Vol. 2 across the project lifecycle; gate merges/releases until evidence-backed tasks are complete.

Operational Narrative [Informative]

Inputs used (authoritative sources):

- **Project/Portfolio Management Webhooks (Jira/Azure DevOps REST):** phase transitions, approvals, responsible roles, artifact links.
- **CI/CD Pipeline Events (GitHub/GitLab/ADO webhooks):** build/test outcomes, SAST/DAST/SCA summaries, code coverage, artifact URIs.
- **Requirements/Design Baseline Events (Git/ReqIF/Docs):** baselined security requirements, control mappings, test traceability matrices.

Model training / knowledge (what the LLM relies on):

- Prompt pack with SSE task catalog and gating rules (NIST 800-160v2 tasks, 800-53 SA/PM families; org policy thresholds).
- RAG sources: requirements repo, traceability matrices, past waivers/exceptions, CI security check catalog; do not train on regulated evidence—use evidence_refs.

- Guardrails: read-only on source systems except scoped endpoints for status checks/PR comments; allowlist per project; strict field-level schema validation on outputs.

Decisions it makes (deterministic + model-assisted):

- **Task completion evaluation:** mark each SSE task pass/fail with evidence links (e.g., “ThreatModel: pass (evidence_ref ...)”).
- **Compliance scoring:** compute sse_compliance_score and blocking status by release/branch.
- **Gate outcomes:** set ReleaseGateDecision = pass|fail|pending based on constraints (e.g., block_release_if_sse_incomplete, min_coverage).
- **Escalation & waivers:** open/route waiver workflow when deadlines or thresholds not met; require HITL for risk trade-offs.

Routing / where outputs go:

- **SSEChecklistStatus** → event bus (Kafka/AMQP) and/or REST endpoint; also posted to project “Readiness” dashboard.
- **ReleaseGateDecision** → CI status checks / environments API; prevents merge/release when failing.
- **Optional PR review comments** → design/code PR threads with inline references to missing evidence.

Automation scope vs. manual/HITL:

- Fully automated: event ingestion, correlation across mission_id and system_mission_id, rule evaluation, status emission, status-check updates.
- **HITL required:** acceptance of residual High/Critical risk, approval of waivers/exceptions, interpretation of ambiguous artifacts.
- Manual outside agent: redefining SSE task catalog/thresholds; program-level risk acceptance.

Security Domain: Security Architecture & Systems Engineering

Inputs (native protocols consumed) [Informative]

1. **Project/Portfolio Management Webhooks (Jira/ADO REST)** — phase transitions and approvals.

2. **CI/CD Pipeline Events (GitHub/GitLab/ADO)** — security gates and coverage metrics.
3. **Requirements/Design Baseline Events (Git/ReqIF/Docs)** — baseline and traceability coverage.

Example: Consumed Protocol — Project/Portfolio Management Webhooks

[Informative]

Native payload (Epic phase transition)

```
{
  "event_id": "jira-evt-PRJ-217-phase",
  "project_key": "PRJ",
  "epic_key": "PRJ-217",
  "from_status": "Design In Progress",
  "to_status": "Design Complete",
  "approver": "security.arch.lead",
  "approved": true,
  "timestamp": "2025-08-15T14:05:12Z",
  "artifacts": [
    "uri://git/arch/payments/diagrams/payments.puml@b17a53f",
    "uri://git/requirements/REQ-PAY-SEC-001.json@v1.2"
  ]
}
```

MCP-wrapped payload

```
{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-i2-sse-1111-2222-3333-4444",
    "thread_id": "uuid-sse-PRJ-217-design-gate",
    "task_id": "uuid-aaa1-bbb2-ccc3-ddd4",
  }
}
```

```

"role": "SSEProcessAgent",
"intent": "assure",
"system_mission_id": "uuid-sys-payments-0001",
"policy_refs": ["SA-3", "SA-8", "SA-10", "800-160v2:ArchEval"],
"constraints": ["no_merge_without_threat_model"],
"decision_basis": {
  "evidence_refs": [
    "uri://jira/PRJ-217/events/jira-evt-PRJ-217-phase",
    "uri://git/arch/payments/diagrams/payments.puml@b17a53f",
    "uri://git/requirements/REQ-PAY-SEC-001.json@v1.2"
  ],
  "confidence": 0.94,
  "explanation_ref": "uri://kb/sse/gates/design-complete"
},
"provenance": {
  "producer_spiffe": "spiffe://enterprise/sse/sse-process-agent",
  "signing_kid": "kid-jira-i2-01",
  "attestation_ref": "uri://slsa/attestations/sse-process@sha256:jira01"
},
"classification": "C2",
"legal_hold": false
},
"native_payload": { "...": "..." }
}

```

Example: Consumed Protocol — CI/CD Pipeline Events [Informative]

Native payload (workflow run with security gates)

```
{
```

```
"workflow_run_id": 4182271,  
"repo": "payments/service-api",  
"branch": "main",  
"commit": "b17a53f",  
"conclusion": "success",  
"checks": {  
  "sast": {"status": "pass", "high_findings": 0},  
  "dast": {"status": "pass", "high_findings": 0},  
  "sca": {"status": "pass", "critical_vulns": 0},  
  "coverage": {"status": "pass", "pct": 83.4}  
},  
"artifacts": [  
  "uri://ci/artifacts/sast/b17a53f.sarif",  
  "uri://ci/artifacts/dast/b17a53f.html",  
  "uri://ci/artifacts/coverage/b17a53f.json"  
],  
"ended_at": "2025-08-15T14:20:31Z"  
}
```

MCP-wrapped payload

```
{  
  "mcp_context": {  
    "mcp_version": "0.9",  
    "mission_id": "uuid-i2-sse-1111-2222-3333-4444",  
    "thread_id": "uuid-ci-payments-service-api@b17a53f",  
    "task_id": "uuid-eee5-fff6-1111-2222",  
    "role": "SSEProcessAgent",  
    "intent": "assure",  
  },  
}
```

```

"system_mission_id": "uuid-sys-payments-0001",
"policy_refs": ["SA-11", "RA-5", "800-160v2:VerifyValidate"],
"constraints": ["block_release_if_sse_incomplete", "min_coverage:80"],
"decision_basis": {
  "evidence_refs": [
    "uri://github/actions/workflow_runs/4182271",
    "uri://ci/artifacts/sast/b17a53f.sarif",
    "uri://ci/artifacts/dast/b17a53f.html",
    "uri://ci/artifacts/coverage/b17a53f.json"
  ],
  "confidence": 0.97,
  "explanation_ref": "uri://kb/sse/gates/ci-security-gates"
},
"provenance": {
  "producer_spiffe": "spiffe://enterprise/sse/sse-process-agent",
  "signing_kid": "kid-ci-i2-02",
  "attestation_ref": "uri://slsa/attestations/sse-process@sha256:ci02"
},
"classification": "C2",
"legal_hold": false
},
"native_payload": { "...": "..." }
}

```

Example: Consumed Protocol — Requirements/Design Baseline Events

[Informative]

Native payload (security requirements baseline)

```
{
```

```

"baseline_id": "SEC-REQS-PAY-1.2",
"doc_ref": "uri://git/requirements/REQ-PAY-SEC-001.json@v1.2",
"traceability": {
  "controls_mapped": ["SC-13", "SC-8", "IA-2", "AC-7", "SC-12", "SC-28"],
  "tests_linked": 42,
  "coverage_pct": 91.0
},
"owner": "security.requirements",
"timestamp": "2025-08-15T13:55:00Z"
}
MCP-wrapped payload
{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-i2-sse-1111-2222-3333-4444",
    "thread_id": "uuid-baseline-SEC-REQS-PAY-1.2",
    "task_id": "uuid-cc31-dd42-ee53-ff64",
    "role": "SSEProcessAgent",
    "intent": "assure",
    "system_mission_id": "uuid-sys-payments-0001",
    "policy_refs": ["SA-3", "SA-8", "SA-10", "PM-16", "800-160v2:ReqsTraceability"],
    "constraints": ["block_release_if_sse_incomplete"],
    "decision_basis": {
      "evidence_refs": ["uri://git/requirements/REQ-PAY-SEC-001.json@v1.2"],
      "confidence": 0.95,
      "explanation_ref": "uri://kb/sse/traceability-coverage#thresholds"
    }
  },

```

```

"provenance": {
  "producer_spiffe": "spiffe://enterprise/sse/sse-process-agent",
  "signing_kid": "kid-req-i2-03",
  "attestation_ref": "uri://slsa/attestations/sse-process@sha256:req03"
},
"classification": "C2",
"legal_hold": false
},
"native_payload": { "...": "..." }
}

```

Outputs (native) [Informative]

- **SSEChecklistStatus** (task-by-task pass/fail, evidence links, blocking flag).
- **Optional:** PR review comments and **ReleaseGateDecision** status checks (pass/fail) on branches/releases.

MCP context (required) [Informative]

mission_id; role="SSEProcessAgent"; intent="assure"; system_mission_id; policy_refs (e.g., SA-3, SA-8, SA-10, PM-16; 800-160v2 task IDs); provenance (SPIFFE ID, signing KID, attestation)

MCP context (optional) [Informative]

constraints (e.g., "block_release_if_sse_incomplete", "no_merge_without_threat_model", "min_coverage:80"); classification (usually C2); decision_basis (evidence_refs, confidence, explanation_ref); legal_hold

Enforcement note [Informative]

PEPs, PR checks, and deployment gates **MUST** enforce constraints such as "block_release_if_sse_incomplete" and "no_merge_without_threat_model"; merges/releases **MUST** fail while any **Required** SSE task is incomplete or below thresholds.

NIST SP 800-160v2 linkage [Informative]

Plan → Design → Implement → Evaluate → Maintain SSE tasks; evidence-driven gates (threat modeling, control allocation, verification/validation, supply-chain assurance).

Automation feasibility [Informative]

Partial–High (event ingestion, correlation, and gate logic are automatable; risk trade-offs/waivers are HITL).

Output Contracts (merged) [Informative]

OC-1: SSEChecklistStatus [Informative]

- **Producer(s):** I2
- **Topic/Path:** sec.sse.checklist.status (Kafka/AMQP) or POST /sse/{mission_id}/status
- **Schema/Format:** SSEChecklistStatus@1.0 (tasks[], status=pass|fail|pending, evidence_refs[], sse_compliance_score, blocking=true|false, thresholds, rationale_url)
- **Classification:** C2
- **Delivery:** at-least-once
- **Ordering:** per-mission_id
- **Idempotency-Key:** sha256(mission_id, system_mission_id, baseline_id_or_version, last_ci_run_id)
- **Ack/Nack:** 202/201 ACK; 4xx/5xx NACK
- **Timeouts/Retry:** ack<=60s; exp-backoff<=5x; open waiver ticket on repeated NACK if blocking=true
- **Side-Effects:** append checklist snapshot to readiness index; notify project channel if blocking=true
- **HITL Token:** required to override blocking=true or to accept residual High risk
- **Observability:** trace_id, mission_id, system_mission_id, decision_basis.*, classification_label, provenance.attestation
- **Retention/TTL:** 7 years or per safety-critical policy

Schema Capsule (OC-1) [Normative]

Requirement Level: Required

Condition: Always

schema_id=SSEChecklistStatus@1.0 | json_schema_uri=uri://schema/sse-checklist-status-1.0.json | sha256= | producers=I2 | consumers=Readiness-Portal-01, CI-

StatusSync-01, GRC-01 | accepts=1.0–1.x

Conformance: This capsule and the corresponding MCP schema define testable requirements.

OC-2: ReleaseGateDecision [Informative]

- **Producer(s):** I2
- **Topic/Path:** CI status checks API (e.g., POST /repos/{repo}/statuses/{sha}) or sec.sse.release.gate
- **Schema/Format:** ReleaseGateDecision@1.0 (repo, ref, sha, environment, decision=pass|fail|pending, reasons[], blocking=true|false, required_tasks[], thresholds)
- **Classification:** C1 (sanitized)
- **Delivery:** exactly-once per sha+environment (consumer enforces)
- **Ordering:** per-sha
- **Idempotency-Key:** sha256(repo, sha, environment, required_policy_set_hash)
- **Ack/Nack:** 201 Created; retry/backoff on 5xx; escalate to HITL after 5 retries if blocking=true
- **Side-Effects:** gate merge/release; annotate checks UI with links to SSEChecklistStatus snapshot
- **HITL Token:** required to “force pass” when blocking=true
- **Observability:** trace_id, mission_id, system_mission_id, policy_refs, constraints
- **Retention/TTL:** per CI retention (>= 1 year)

Schema Capsule (OC-2) [Normative]

Requirement Level: Conditionally Required

Condition: When "block_release_if_sse_incomplete" is active or CI supports mandatory status checks

schema_id=ReleaseGateDecision@1.0 | json_schema_uri=uri://schema/release-gate-decision-1.0.json | sha256= | producers=I2 | consumers=GitHub-Checks-01, GitLab-Status-01, ADO-Gates-01 | accepts=1.0–1.x

Conformance: Normative when condition is met.

OC-3: SSEPRReviewComment [Informative, optional]

Copyright © 2025 John M. Willis and Quantum Powered Security, Inc. • CC BY 4.0

- **Producer(s):** I2
- **Topic/Path:** POST /repos/{repo}/pulls/{pr}/comments or sec.sse.pr.comments
- **Schema/Format:** SSEPRReviewComment@1.0 (pr_id, file_path, line_or_anchor, comment_text, task_ref, severity, evidence_refs[])
- **Classification:** C1
- **Delivery:** at-least-once
- **Ordering:** per-pr_id
- **Idempotency-Key:** sha256(pr_id, file_path, line_or_anchor, comment_text_hash)
- **Ack/Nack:** 201 Created; retry/backoff
- **Side-Effects:** links comment to SSEChecklistStatus finding_ids; updates PR checklist
- **HITL Token:** none (advisory; gating handled by OC-2)
- **Observability:** trace_id, mission_id, pr_id, task_ref
- **Retention/TTL:** repo policy

Schema Capsule (OC-3) [Normative]

Requirement Level: Optional

Condition: When PR platforms are in scope for developer visibility

schema_id=SSEPRReviewComment@1.0 | json_schema_uri=uri://schema/sse-pr-review-comment-1.0.json | sha256= | producers=I2 | consumers=PRBot-01 | accepts=1.0–1.x

Conformance: Normative if implemented or claimed.

State machine (concise) [Informative]

```
states = { idle, awaiting_phase_event, ingesting_ci, correlating_baselines,
evaluating_sse_tasks, emitting_status, gating_release, awaiting_HITL, failed, closed }
transition(idle -> awaiting_phase_event) when mission_id registered
transition(awaiting_phase_event -> correlating_baselines) when phase transition
approved=true
transition(correlating_baselines -> ingesting_ci) when baseline coverage >=
threshold_min
transition(ingesting_ci -> evaluating_sse_tasks) when CI artifacts present
transition(evaluating_sse_tasks -> emitting_status) when rule evaluation complete
```

transition(emitting_status -> gating_release) when blocking=true and constraints include
 block_release_if_sse_incomplete
 transition(gating_release -> awaiting_HITL) when override requested or waiver needed
 transition(* -> failed) on schema/timeout/auth errors
 timeout(gating_release, 60s) -> failed; retry <= 5 with exp backoff
 idempotency_key = sha256(mission_id, system_mission_id, baseline_id_or_version,
 last_ci_run_id)

Output Contracts Summary [Normative]

Output Contract	Requirement Level	Trigger Condition	Business Impact
OC-1 SSEChecklistStatus	Required	Always	Central readiness record
OC-2 ReleaseGateDecision	Conditionally Required	block_release_if_sse_incomplete active or CI supports mandatory status checks	Enforces merge/release gates
OC-3 SSEPRReviewComment	Optional	PR platform in scope	Developer visibility and guidance

Requirement Level Definitions:

- **Required:** Must be implemented for conformant deployment
- **Conditionally Required:** Must be implemented when trigger condition is met
- **Optional:** May be implemented for enhanced functionality

Policies and HITL gates [Informative]

- policy_refs: SA-3, SA-8, SA-10, SA-11, PM-16; 800-160v2 task IDs (planning, architecture eval, verification/validation, sustainment).
- **HITL required:** to override blocking gates, accept residual High/Critical risk, approve waivers.
- **Automatic HITL escalation triggers:** model_confidence < theta_low; missing_required_evidence=true; coverage < min_coverage; overdue_tasks > 0.

- **Manual outside agent:** program-level risk acceptance; redefining thresholds.

SLOs and KPIs [Informative]

- StatusEmit_p95 <= 60 s from last evidence ingestion
- GateDecisionLatency_p95 <= 15 s
- FalseBlockRate_30d <= 2 percent
- WaiverTurnaround_p95 <= 3 business days

Outputs index [Informative]

[OC-1 SSEChecklistStatus], [OC-2 ReleaseGateDecision], [OC-3 SSEPRReviewComment]

Technical Implementation Details (I2) [Informative]

Model and training profile [Informative]

model_id=sse-process-text-model; temperature=0.1; max_tokens_out=800
 prompt_pack_id=sse-gates-v1 (SSE task catalog, thresholds, few-shots)
 RAG: sources={SSE task catalog, org policy thresholds, prior checklists, waiver corpus};
 max_docs=10; min_similarity=0.78; citations required
 fine_tuning/adapters: none initially; evaluate on precision of gating and false-block rate
 guardrails: output schemas locked; only scoped tokens for CI status/PR APIs

Memory and state [Informative]

working_memory.max_tokens=4k; eviction=recency_then_importance
 episodic_memory: per mission_id/system_mission_id journal of events and decisions;
 ttl=365d
 semantic_memory: namespaces=["sse-tasks","waivers","ci-checks"]; embeddings=text-embedding-sec-v1; k=10
 durable_state_store: event-sourced ledger; snapshots at each gate change
 consistency: at-least-once (OC-1); exactly-once per sha for OC-2
 idempotency: as defined in Output Contracts

Decision and routing logic [Informative]

- **Compliance score:**

$$\text{sse_compliance_score} = 0.3\text{reqs_traceability} + 0.25\text{threat_model_status} + 0.2\text{ci_security_checks} + 0.15\text{coverage_pct_norm} + 0.1*\text{supply_chain_assurance}$$
 where $\text{coverage_pct_norm} = \min(\text{coverage_pct} / \text{min_coverage_threshold}, 1.0)$

- **Gate rule (simplified):**
release_gate_pass = all_required_tasks_complete AND coverage_pct >= min_coverage AND ci_checks_pass AND no_open_high_findings
- **Routing:** if release_gate_pass=false and constraints include block_release_if_sse_incomplete → emit OC-1 (blocking=true) + OC-2(fail).
If minor gaps and waiver_requested=true → emit OC-1(blocking=true) and move to awaiting_HITL.

Model Risk Management [Informative]

continuous_validation: daily; suites=[goldens, adversarial evidence mixes, flaky CI runs]
thresholds: eval_pass_rate >= 99.0 percent → auto_HITL if below
red_team_cycle: monthly probes (e.g., spoofed coverage, forged SARIF)
rollback_policy: eval_drop >= 1.5 pp for 48 h → revert model_id; notify owners

Transparency and Audit Trail (Approver/Auditor UX) [Informative]

decision_rationale_template: which required tasks failed, evidence_refs, thresholds, links to CI artifacts
UI/API: expose classification_label, provenance.attestation, rationale_url
audit_log_format: JSONL; retention bound by legal_hold or org policy

Incident Response Integration [Informative]

Post-incident lessons learned update SSE task catalog thresholds; re-evaluate missions with related stack/patterns.

Change Impact Assessment [Informative]

When baseline or CI artifacts change, recompute sse_compliance_score_delta and include in OC-1.status.change_impact.

Stakeholder Feedback Loop [Informative]

Capture developer/security lead feedback labels={useful|noise|flaky-check}; route to governance-reviewed updates of thresholds.

Data Sovereignty and Legal Hold [Informative]

classification default C2; legal_hold=true freezes purge and retains OC snapshots beyond standard TTL.

Interfaces (links only) [Informative]

Consumes: Project/Portfolio Webhooks; CI/CD Pipeline Events; Requirements/Design Baseline Events

Produces: OC-1 SSEChecklistStatus; OC-2 ReleaseGateDecision; OC-3 SSEPRReviewComment

Safety and abuse prevention [Informative]

kill_switch on anomalous fail/pass oscillations; block “force pass” without HITL token; detect forged artifacts via checksums/attestations.

Testing and validation [Informative]

contract tests for OC-1..OC-3; offline replay of historical runs; mutation tests for constraints (min_coverage, required tasks); negative tests for forged artifacts.

Deployment and lifecycle [Informative]

scale on event rate; canary rulesets; SBOM and SLSA attestations; sign all outputs.

References / Standards [Informative]

NIST SP 800-160 Vol. 2 (Cyber-Resiliency & SSE); NIST SP 800-53 Rev. 5 (SA, PM, RA families); NIST SP 800-218 (SSDF); NIST SP 800-204 series (microservices/DevSecOps); ISO/IEC 27002:2022; CIS Controls v8; SLSA; SPIFFE/SPIRE.

MCP-Native Protocol Specification (I2) [Normative]

(Canonical schemas and validation live here; keep example payloads synchronized with the Agent Blueprint.)

- **Native Protocol(s) Consumed:** Project/Portfolio Management Webhooks; CI/CD Pipeline Events; Requirements/Design Baseline Events
- **Native Protocol(s) Produced:** SSEChecklistStatus (events/REST); ReleaseGateDecision (CI status checks); SSEPRReviewComment (PR APIs)
- **MCP Context Fields:**
 - **Required:** mission_id; role="SSEProcessAgent"; intent="assure"; system_mission_id; policy_refs=[...] ; provenance.attestation (SPIFFE + KID)
 - **Optional:** constraints (e.g., "block_release_if_sse_incomplete","no_merge_without_threat_model","min_coverage:80"); classification; decision_basis; legal_hold

- **Enforcement Note:** PR/CI gates MUST honor ReleaseGateDecision and block merges/releases when blocking=true; HITL token required to override.
- **Versioning and compatibility; producers/consumers registry:** authoritative in the schema registry; see Schema Capsules for accepted ranges/EOL.
- **Example payloads:** native and MCP-wrapped examples above are authoritative.
- **Transparency hooks:** classification_label, provenance.attestation, decision_rationale_url available to downstream UIs/APIs.

Conformance: This section is **[Normative]** and, together with each **Schema Capsule**, defines testable requirements.

I3. Crypto Architecture Agent

Agent Blueprint [Informative]

Purpose: Design the enterprise cryptographic architecture (hierarchies, key flows, crypto boundaries). Select FIPS-validated modules, define algorithms/parameters, key lifecycle, and control-plane integrations (HSM/KMS/CA). Produce an authoritative **CryptoDesignDoc** with traceable control mappings and component attestations.

Operational Narrative [Informative]

Inputs used (authoritative sources):

- **Security Requirements (Git/ReqIF/Docs):** crypto and protection requirements; required controls and parameters; acceptance criteria; version metadata.
- **Asset Inventory (CMDB/Asset Graph REST/GraphQL):** systems, data classes, trust zones, flows, throughput, crypto boundaries, existing KMS/HSM bindings.

Model training / knowledge (what the LLM relies on):

- Prompt pack with crypto patterns and guardrails (key hierarchy patterns, TLS profiles, mTLS, PKI, at-rest encryption, tokenization, secrets handling).
- RAG sources: requirements corpus, control catalogs (NIST 800-53 SC, SA; NIST 800-57/56; 800-52 profiles), prior CryptoDesignDocs, module attestations registry; do not train on regulated key material—use evidence_refs.
- Guardrails: algorithm allowlist by policy; deny-list deprecated suites; required FIPS 140-3 validation checks; constrained functions for KMS/HSM discovery only.

Decisions it makes (deterministic + model-assisted):

- **Algorithm/profile selection:** choose ciphers, key sizes, protocol versions per constraints and data class criticality.
- **Key hierarchy design:** root-of-trust, tenant KMS, KEK/DEK separation, envelope encryption paths.
- **Boundary placement:** define crypto boundaries and trust zones; mandate mTLS and certificate policies between zones.
- **Lifecycle policy:** crypto_period, rotation windows, re-wrapping, backup encryption, escrow prohibition, attestation requirements.
- **Control mappings:** link each design element to control IDs and evidence sources.
- **Exceptions:** detect where requirements cannot be met; propose compensating controls; route to waiver workflow (HITL).

Routing / where outputs go:

- **CryptoDesignDoc** → Docs/Git repo (Markdown + diagrams + bill-of-crypto-materials).
- **Optional CryptoDesignDecision** events → governance bus for traceability (link to PRs, tickets, and attestations).
- Optional PR comments → design or infra repos when crypto deltas are required (e.g., “enable TLS 1.3; enforce cipher set X”).

Automation scope vs. manual/HITL:

- Fully automated: requirements ingestion, asset scoping, pattern synthesis, default profile selection, doc generation, evidence link stitching.
- **HITL required:** exceptions and compensating controls; approval of non-standard algorithms; PQC transition plans; cross-domain key escrow debates.
- Manual outside agent: vendor procurement and hardware selection; legal/regulatory interpretation for sovereign crypto controls.

Security Domain: Security Architecture & Systems Engineering

Inputs (native protocols consumed) [Informative]

1. **Security Requirements (Git/ReqIF/Docs)** — ingest crypto requirements and control mappings.

2. **Asset Inventory (CMDB/Asset Graph REST/GraphQL)** — enumerate assets, data classes, zones, and crypto boundaries.

Example: Consumed Protocol — Security Requirements [Informative]

Native payload (ReqIF-like JSON extract)

```
{
  "doc_id": "REQ-CRYPTO-ORG-01",
  "title": "Enterprise Cryptography Requirements v2.3",
  "requirements": [
    {"id": "CR-ALG-01", "text": "Only FIPS 140-3 validated modules.", "controls": ["SC-12", "SC-13"]},
    {"id": "CR-TLS-01", "text": "TLS 1.3 with PFS; suites: TLS_AES_256_GCM_SHA384, TLS_CHACHA20_POLY1305_SHA256.", "controls": ["SC-8", "SC-13", "SP800-52r2"]},
    {"id": "CR-REST-01", "text": "At-rest: AES-256-GCM; keys in HSM-backed KMS; crypto period <= 90 days.", "controls": ["SC-12", "SC-28", "SP800-57"]},
    {"id": "CR-KM-01", "text": "Root/tenant KMS hierarchy with DEK/KEK separation.", "controls": ["SC-12", "SA-9", "SP800-57"]},
    {"id": "CR-PKI-01", "text": "Service mTLS with ECDSA P-256; OCSP must-staple; CT logging.", "controls": ["SC-12", "SC-23"]}
  ],
  "version": "2.3",
  "owner": "security.crypto.arch",
  "updated": "2025-08-15T12:45:00Z"
}
```

MCP-wrapped payload

```
{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-i3-crypto-1111-2222-3333-4444",
    "thread_id": "uuid-reqs-REQ-CRYPTO-ORG-01",
  }
}
```

```

"task_id": "uuid-a1b2-c3d4-e5f6-7788",
"role": "CryptoArchitectureAgent",
"intent": "design",
"policy_refs": ["SC-12", "SC-13", "SC-28", "SC-8", "SP800-57", "SP800-56A", "SP800-52r2", "FIPS140-3"],
"constraints": ["fips140-3_validated:true", "crypto_period_days:90", "min_key_bits:256_sym/3072_rsa/256_ec"],
"decision_basis": {
  "evidence_refs": ["uri://git/reqs/REQ-CRYPTO-ORG-01.json@v2.3"],
  "confidence": 0.96,
  "explanation_ref": "uri://kb/crypto/reqs-to-architecture-trace"
},
"provenance": {
  "producer_spiffe": "spiffe://enterprise/arch/crypto-architecture-agent",
  "signing_kid": "kid-req-i3-01",
  "attestation_ref": "uri://slsa/attestations/crypto-architecture@sha256:req01"
},
"classification": "C2",
"legal_hold": false
},
"native_payload": { "...": "..." }
}

```

Example: Consumed Protocol — Asset Inventory [Informative]

Native payload (crypto-relevant asset slice)

```

{
  "query_id": "crypto-scope-2025-08-15",
  "assets": [

```

```

    {"asset_id":"gw-edge-01","type":"api_gateway","zone":"dmz","data_classes":["public","session_tokens"],"flows":["internet->gw-edge-01","gw-edge-01->auth-svc"],"throughput_rps":12000,"mtls_required":true},
    {"asset_id":"db-payments-01","type":"postgresql","zone":"prod","data_classes":["pci","pii"],"storage":"ebs","kms_keyring":"arn:aws:kms:.../keystore-01","backup_encrypt":true}
  ],
  "generated_at": "2025-08-15T13:05:00Z"
}

```

MCP-wrapped payload

```

{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-i3-crypto-1111-2222-3333-4444",
    "thread_id": "uuid-cmdb-crypto-scope-2025-08-15",
    "task_id": "uuid-99aa-bbcc-ddee-ff00",
    "role": "CryptoArchitectureAgent",
    "intent": "design",
    "policy_refs": ["SC-12","SC-13","SC-28","AC-17"],
    "constraints": ["fips140-3_validated:true","alg_allowlist:[TLS1.3,AES-256-GCM,ECDHE-ECDSA-P256]"],
    "decision_basis": {
      "evidence_refs": ["uri://cmdb/queries/crypto-scope-2025-08-15"],
      "confidence": 0.94,
      "explanation_ref": "uri://kb/crypto/asset-to-crypto-boundary-mapping"
    },
    "provenance": {
      "producer_spiffe": "spiffe://enterprise/arch/crypto-architecture-agent",

```

```

    "signing_kid": "kid-cmdb-i3-02",
    "attestation_ref": "uri://slsa/attestations/crypto-architecture@sha256:cmdb02"
  },
  "classification": "C2",
  "legal_hold": false
},
"native_payload": { "...": "..." }
}

```

Outputs (native) [Informative]

- **CryptoDesignDoc** (Docs/Git artifact with diagrams and bill-of-crypto-materials).
- **Optional: CryptoDesignDecision** events for governance traceability.

MCP context (required) [Informative]

mission_id; role="CryptoArchitectureAgent"; intent="design"; policy_refs (e.g., NIST 800-53 SC-12/SC-13/SC-28, NIST 800-57/56, 800-52r2, FIPS 140-3); provenance (SPIFFE ID, signing KID, attestation_ref for intended crypto components)

MCP context (optional) [Informative]

constraints (e.g., "alg_allowlist:[TLS1.3{AES-256-GCM,CHACHA20-POLY1305},RSA-3072,ECDSA-P256]", "min_key_bits:256_sym/3072_rsa/256_ec", "crypto_period_days:90", "fips140-3_validated:true"); classification (C2–C3); decision_basis; legal_hold

Enforcement note [Informative]

PEPs and release gates MUST verify that selected modules are FIPS 140-3 validated and produced profiles honor algorithm/key constraints; services MAY NOT deploy where CryptoDesignDoc state is absent or non-conformant for the mission_id.

NIST SP 800-160v2 linkage [Informative]

Design and Implement trustworthy crypto mechanisms with evidence-backed selection; Evaluate and Maintain key lifecycle, rotation, and retirement.

Automation feasibility [Informative]

Partial–High: requirements and asset parsing, pattern synthesis, doc generation, and validation are automatable; exceptions and trade-offs require HITL.

Output Contracts (merged) [Informative]

OC-1: CryptoDesignDoc [Informative]

- **Producer(s):** I3
- **Topic/Path:** repo=sec/crypto-designs/<mission_id>.md and assets/diagrams/*.puml|drawio; optional oci://artifacts/crypto/<mission_id>:<version>
- **Schema/Format:** CryptoDesignDoc@1.0 (header, scope, controls_map[], profiles[], key_hierarchy, lifecycle_policy, boundaries[], bill_of_crypto_materials, attestations[], evidence_refs[], decision_rationale_url)
- **Classification:** C2 (C3 if includes sensitive topology or key paths)
- **Delivery:** at-least-once
- **Ordering:** per-mission_id
- **Idempotency-Key:** sha256(mission_id, reqs_version, asset_query_id)
- **Ack/Nack:** 201 Created (Git/Docs); NACK on 4xx/5xx
- **Timeouts/Retry:** ack<=60s; exp-backoff<=5x; on persistent failure, open governance ticket
- **Side-Effects:** update crypto registry index; attach attestations and control evidence links
- **HITL Token:** required to approve non-standard algorithms or waive FIPS validation
- **Observability:** trace_id, mission_id, policy_refs, constraints, classification_label, provenance.attestation
- **Retention/TTL:** 7 years (or as per regulated context)

Schema Capsule (OC-1) [Normative]

Requirement Level: Required

Condition: Always

schema_id=CryptoDesignDoc@1.0 | json_schema_uri=uri://schema/crypto-design-doc-1.0.json | sha256= | producers=I3 | consumers=DesignPortal-01, GRC-01, CI-Policy-01 | accepts=1.0–1.x

Conformance: This capsule and the corresponding MCP schema define testable requirements.

OC-2: CryptoDesignDecision [Informative]

- **Producer(s):** I3
- **Topic/Path:** sec.crypto.decision (Kafka/AMQP)
- **Schema/Format:** CryptoDesignDecision@1.0 (mission_id, decision_type, profiles[], key_params, fips_modules[], justification, control_refs[], attestation_refs[], change_impact, links={doc_url, prs[], tickets[]})
- **Classification:** C1–C2
- **Delivery:** at-least-once
- **Ordering:** per-mission_id
- **Idempotency-Key:** sha256(mission_id, decision_type, doc_digest)
- **Ack/Nack:** 202/201 ACK; 4xx/5xx NACK
- **Timeouts/Retry:** ack<=30s; retry<=5x; escalate to HITL on repeated NACK
- **Side-Effects:** append to governance trail; trigger PR comments or tickets when action required
- **HITL Token:** required to emit decisions that deviate from policy constraints
- **Observability:** trace_id, mission_id, decision_type, classification_label, provenance.attestation
- **Retention/TTL:** 3 years

Schema Capsule (OC-2) [Normative]

Requirement Level: Optional

Condition: When governance bus traceability is enabled or required by policy
schema_id=CryptoDesignDecision@1.0 | json_schema_uri=uri://schema/crypto-design-decision-1.0.json | sha256= | producers=I3 | consumers=Governance-01, PRBot-01 | accepts=1.0–1.x

Conformance: Normative if implemented or claimed.

State machine (concise) [Informative]

states = { idle, ingesting_requirements, scoping_assets, synthesizing_profiles, drafting_hierarchy, validating_constraints, generating_doc, awaiting_HITL, publishing, failed, closed }

transition(idle -> ingesting_requirements) when new or updated crypto requirements detected
 transition(ingesting_requirements -> scoping_assets) when reqs_version parsed
 transition(scoping_assets -> synthesizing_profiles) when asset query complete
 transition(synthesizing_profiles -> drafting_hierarchy) when profile candidates selected
 transition(drafting_hierarchy -> validating_constraints) when key flows and boundaries modeled
 transition(validating_constraints -> generating_doc) when all constraints satisfied or exceptions flagged
 transition(generating_doc -> publishing) on schema validate OK
 transition(publishing -> awaiting_HITL) when exceptions or non-standard algorithms present
 transition(* -> failed) on schema/timeout/auth errors
 idempotency_key = sha256(mission_id, reqs_version, asset_query_id)

Output Contracts Summary [Normative]

Output Contract	Requirement Level	Trigger Condition	Business Impact
OC-1 CryptoDesignDoc	Required	Always	Authoritative crypto blueprint
OC-2 CryptoDesignDecision	Optional	Governance bus enabled or policy requires traceability	Change ledger and downstream actions

Requirement Level Definitions:

- **Required:** Must be implemented for conformant deployment
 - **Conditionally Required:** Must be implemented when trigger condition is met
 - **Optional:** May be implemented for enhanced functionality
-

Policies and HITL gates [Informative]

- **policy_refs:** SC-12, SC-13, SC-28, SC-8, SA-9, SC-23 (+ org profiles); references to NIST 800-57/56 and TLS profile guidance.
- **HITL required:** any deviation from alg_allowlist; crypto_period > policy; non-FIPS modules; PQC pilots in production; cross-border key residency exceptions.

- **Automatic HITL escalation triggers:** model_confidence < theta_low; module_attestation_missing=true; deprecated_cipher_detected=true; data_class="pci|phil|pii" and constraints violated.
- **Manual outside agent:** vendor/module procurement; legal review for sovereignty constraints.

SLOs and KPIs [Informative]

- DesignDocPublish_p95 <= 60 s after inputs stabilized
- ExceptionDecisionTurnaround_p95 <= 5 business days
- NonConformantDeployments_30d == 0
- AttestationCoverage >= 99 percent of in-scope components

Outputs index [Informative]

[OC-1 CryptoDesignDoc], [OC-2 CryptoDesignDecision]

Technical Implementation Details (I3) [Informative]

Model and training profile [Informative]

model_id=crypto-arch-text-model; temperature=0.1; max_tokens_out=1000
 prompt_pack_id=crypto-arch-v1 (key hierarchy patterns, TLS profiles, PKI policies, few-shots)

RAG: sources={crypto requirements repo, asset graph, attestation registry, control catalogs, prior designs}; max_docs=12; min_similarity=0.78; citations required
 fine_tuning/adapters: none initially; evaluate on mapping accuracy and constraint adherence

guardrails: enforce alg_allowlist and min_key_bits; require FIPS attestation in outputs when fips140-3_validated=true

Memory and state [Informative]

working_memory.max_tokens=4k; eviction=recency_then_importance
 episodic_memory: per mission_id design journal (inputs, choices, exceptions), ttl=365d
 semantic_memory: namespaces=["crypto-patterns","controls","attestations"];
 embeddings=text-embedding-sec-v1; k=12
 durable_state_store: event-sourced ledger; snapshot per published design version
 consistency: at-least-once (OC-1, OC-2)
 idempotency: as defined in Output Contracts

Decision and routing logic [Informative]

Copyright © 2025 John M. Willis and Quantum Powered Security, Inc. • CC BY 4.0

- **Algorithm selection rule (example):**
prefer AES-256-GCM for data-at-rest; for TLS 1.3 allow suites in {TLS_AES_256_GCM_SHA384, TLS_CHACHA20_POLY1305_SHA256}; require ECDHE-ECDSA with P-256; prefer RSA-3072 only where ECDSA not feasible.
- **Key size constraints:**
sym_bits >= 256; rsa_bits >= 3072; ec_curve in {P-256, P-384}.
- **Crypto period and rotation:**
crypto_period_days <= policy_threshold (default 90); rotate DEKs on schedule and on key compromise signals; re-wrap DEKs with new KEKs on KEK rotation.
- **Key hierarchy construction:**
root_of_trust -> tenant_KMS -> KEK -> DEK; DEK used by services per data class; KEK stored in dedicated HSM cluster.
- **BoCM (bill of crypto materials) assembly:** collect module names and versions, FIPS cert IDs (if available), key types, lengths, usage, residency, rotation schedule.

Model Risk Management [Informative]

continuous_validation: daily; suites=[goldens (standard patterns), adversarial (deprecated suites), ambiguous assets]

thresholds: eval_pass_rate >= 99.0 percent → auto_HITL if below

red_team_cycle: monthly tests for weak or deprecated algorithms and forged attestations

rollback_policy: eval_drop >= 1.5 percentage points for 48 h → revert model_id; notify owners

Transparency and Audit Trail (Approver/Auditor UX) [Informative]

decision_rationale_template: requirement -> choice -> control mapping -> evidence_refs -> attestation_refs

UI/API: expose classification_label, provenance.attestation, decision_rationale_url

audit_log_format: JSONL with stable field order; retention per classification/legal_hold

Incident Response Integration [Informative]

If incident involves crypto failure, emit addendum to CryptoDesignDoc with corrective actions; propagate design changes to missions sharing the profile.

Change Impact Assessment [Informative]

On asset or requirement updates, compute `crypto_profile_delta` and affected services; include `change_impact` in OC-2 when emitted.

Stakeholder Feedback Loop [Informative]

Capture reviewer labels={approved|needs_change|non_standard}; incorporate into `prompt_pack` after governance review; never auto-train on key material.

Data Sovereignty and Legal Hold [Informative]

classification default C2; designs with key path details may be C3; `legal_hold=true` overrides TTL and freezes purge.

Interfaces (links only) [Informative]

Consumes: Security Requirements; Asset Inventory

Produces: OC-1 `CryptoDesignDoc`; OC-2 `CryptoDesignDecision`

Safety and abuse prevention [Informative]

`kill_switch` when non-allowlisted algorithms surface; prohibit printing or exporting raw key material; require attestations for module claims.

Testing and validation [Informative]

contract tests for OC-1..OC-2; replay known designs; negative tests for deprecated suites and missing FIPS validation; drift checks vs. policy.

Deployment and lifecycle [Informative]

scale on asset graph size; canary doc generation; SBOM and SLSA attestations; sign all outputs; periodic revalidation against policy baselines.

References / Standards [Informative]

NIST SP 800-160 Vol. 2; NIST SP 800-53 Rev. 5 (SC, SA); NIST SP 800-57; NIST SP 800-56 (A/B as applicable); NIST SP 800-52r2; FIPS 140-3; ISO/IEC 27002:2022; CIS Controls v8.

MCP-Native Protocol Specification (I3) [Normative]

(Canonical schemas and validation live here; keep example payloads synchronized with the Agent Blueprint.)

- **Native Protocol(s) Consumed:** Security Requirements (Git/ReqIF/Docs); Asset Inventory (CMDB/Asset Graph REST/GraphQL)

Copyright © 2025 John M. Willis and Quantum Powered Security, Inc. • CC BY 4.0

- **Native Protocol(s) Produced:** CryptoDesignDoc (Docs/Git artifact); CryptoDesignDecision (events)
- **MCP Context Fields:**
 - **Required:** mission_id; role="CryptoArchitectureAgent"; intent="design"; policy_refs=[SC-12, SC-13, SC-28, SP800-57, SP800-56, SP800-52r2, FIPS140-3]; provenance.attestation (SPIFFE + KID)
 - **Optional:** constraints (alg_allowlist, min_key_bits, crypto_period_days, fips140-3_validated); classification; decision_basis; legal_hold
- **Enforcement Note:** PEPs MUST verify module validation and algorithm/key compliance before deployment; non-conformant services MUST be blocked or remediated.
- **Versioning and compatibility; producers/consumers registry:** authoritative in schema registry; see Schema Capsules for accepted ranges/EOL.
- **Example payloads:** native and MCP-wrapped examples above are authoritative.
- **Transparency hooks:** classification_label, provenance.attestation, decision_rationale_url available to downstream UIs/APIs.

Conformance: This section is **[Normative]** and, together with each **Schema Capsule**, defines testable requirements.

I4. Protocol Compliance Agent

Agent Blueprint [Informative]

Purpose: Verify that security protocols (e.g., TLS, SSH, IPsec, mTLS, OAuth/OIDC) are implemented and configured correctly; detect deprecated versions/ciphers/modes and control-plane misconfigurations; publish a **ProtocolComplianceReport** with findings mapped to standards.

Operational Narrative [Informative]

Inputs used (authoritative sources):

- **Traffic Captures (PCAP/PCAPNG parsed as Zeek/tshark JSON):** negotiated protocol versions, cipher suites, curves/groups, ALPN, OCSP stapling, JA3/JA3S, handshake outcomes per endpoint.
- **Service Configurations (Git/runtime introspection):** TLS/SSH/VPN server configs, policy snippets, certificate chains, OCSP/CRL settings, IPsec/IKE policy sets, OAuth/OIDC provider metadata.

Model training / knowledge (what the LLM relies on):

- Prompt pack with protocol hardening rubrics (TLS 1.3 AEAD-only, SSH KEX/MAC/hostkeys, IPsec/IKEv2 suites, OAuth/OIDC response types/scopes), deprecation timelines (SP 800-131A), and config patterns per platform (nginx, Envoy, HAProxy, OpenSSH, strongSwan).
- RAG sources: standards profiles (NIST 800-52r2, 800-77, 800-63, 800-57, 800-131A, FIPS 140-3), org policy allow/deny lists, prior compliance reports; do not ingest raw secrets—use evidence_refs only.
- Guardrails: read-only in production when constraints include production_readonly; never fetch private keys; only parse configs and handshake metadata.

Decisions it makes (deterministic + model-assisted):

- **Version/suite compliance:** flag non-allowed protocol versions and cipher/MAC/KEX (e.g., TLS 1.0/1.1, CBC in TLS 1.2, RSA key exchange).
- **Control-plane checks:** OCSP must-staple, HSTS, certificate chain trust/expiration, CRL/OCSP reachability, mTLS enforcement between zones.
- **Mapping & severity:** map each finding to standards controls and assign severity based on exposure_surface, data_class, and exploitability.
- **Remediation drafting:** produce platform-specific config diffs/snippets (advisory unless auto-remediation explicitly enabled).

Routing / where outputs go:

- **ProtocolComplianceReport** → event bus (Kafka/AMQP) and/or REST endpoint; link to evidence (pcap-derived records, config blobs).
- **Optional PR comments** → infra repos with inline hardening suggestions.
- **Optional tickets** → issue tracker for Critical/High findings.

Automation scope vs. manual/HITL:

- Fully automated: packet parsing, rules evaluation, standards mapping, report generation.
- **HITL required:** acceptance of compensating controls, exceptions in legacy systems, enabling auto-remediation in production.
- Manual outside agent: certificate procurement/rotation, vendor firmware upgrades, contractually constrained protocol changes.

Security Domain: Security Architecture & Systems Engineering

Inputs (native protocols consumed) [Informative]

1. **Traffic Captures (Zeek/tshark JSON derived from PCAP)** — negotiated parameters and handshake evidence.
2. **Service Configurations (TLS/SSH/VPN Git/runtime)** — declared configuration states for comparison to observed behavior.

Example: Consumed Protocol — Traffic Captures [Informative]

Native payload (Zeek ssl.log-style)

```
{  
  "ts": "2025-08-15T14:35:22Z",  
  "uid": "CHP9IK10",  
  "id.orig_h": "198.51.100.41",  
  "id.orig_p": 53142,  
  "id.resp_h": "203.0.113.20",  
  "id.resp_p": 443,  
  "server_name": "api.example.com",  
  "version": "TLSv1.2",  
  "cipher": "TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA",  
  "curve": "secp256r1",  
  "resumed": false,  
  "alpn": "h2",  
  "ocsp_stapled": false,  
  "ja3": "771,49199-49195-49196,23-65281-0,",  
  "ja3s": "771,49199,23-0,"  
}
```

MCP-wrapped payload

```
{
```

```

"mcp_context": {
  "mcp_version": "0.9",
  "mission_id": "uuid-i4-proto-1111-2222-3333-4444",
  "thread_id": "uuid-trace-api.example.com-2025-08-15T14:35:22Z",
  "task_id": "uuid-a1b2-c3d4-e5f6-7788",
  "role": "ProtocolComplianceAgent",
  "intent": "verify",
  "policy_refs": ["SP800-52r2", "SP800-131A", "FIPS140-3"],
  "decision_basis": {
    "evidence_refs": ["uri://zeek/ssl/api.example.com/CHP9IK10"],
    "confidence": 0.93,
    "explanation_ref": "uri://kb/protocol/tls-policy#tls13-and-aead-required"
  },
  "provenance": {
    "producer_spiffe": "spiffe://enterprise/arch/protocol-compliance-agent",
    "signing_kid": "kid-zeek-i4-01",
    "attestation_ref": "uri://slsa/attestations/protocol-compliance@sha256:zeek01"
  },
  "classification": "C2",
  "legal_hold": false
},
"native_payload": { "...": "..." }
}

```

Example: Consumed Protocol — Service Configurations [Informative]

Native payload (nginx TLS config)

```

server {
  listen 443 ssl http2;

```

```

ssl_protocols TLSv1.3;
ssl_ciphers TLS_AES_256_GCM_SHA384:TLS_CHACHA20_POLY1305_SHA256;
ssl_prefer_server_ciphers on;
ssl_ecdh_curve X25519:P-256;
ssl_stapling on;
add_header Strict-Transport-Security "max-age=31536000; includeSubDomains"
always;
ssl_trusted_certificate /etc/ssl/ca.pem;
ssl_certificate /etc/ssl/cert.pem;
ssl_certificate_key /etc/ssl/key.pem;
}

```

MCP-wrapped payload

```

{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-i4-1111-2222-3333-4444",
    "thread_id": "uuid-conf-api.example.com-nginx@commit:b17a53f",
    "task_id": "uuid-99aa-bbcc-ddee-ff00",
    "role": "ProtocolComplianceAgent",
    "intent": "verify",
    "policy_refs": ["SP800-52r2", "SP800-131A", "SC-8", "SC-13"],
    "decision_basis": {
      "evidence_refs": ["uri://git/infra/nginx/conf/api.example.com@b17a53f"],
      "confidence": 0.97,
      "explanation_ref": "uri://kb/protocol/tls-nginx-hardening"
    },
    "provenance": {

```

```

    "producer_spiffe": "spiffe://enterprise/arch/protocol-compliance-agent",
    "signing_kid": "kid-conf-i4-02",
    "attestation_ref": "uri://slsa/attestations/protocol-compliance@sha256:conf02"
  },
  "classification": "C2",
  "legal_hold": false
},
"native_payload": "server { ... }"
}

```

Outputs (native) [Informative]

- **ProtocolComplianceReport** with endpoint, observed vs. expected, pass/fail per rule, evidence links, remediation guidance.

MCP context (required) [Informative]

mission_id; role="ProtocolComplianceAgent"; intent="verify"; policy_refs (e.g., 800-52r2 TLS, 800-77 IPsec, 800-131A, FIPS 140-3, 800-63/57); provenance (SPIFFE ID, signing KID, attestation)

MCP context (optional) [Informative]

classification (often C2); decision_basis (evidence_refs, confidence, explanation_ref); constraints (e.g., "production_readonly", "min_traces_per_endpoint:3", "no_auto_remediate"); legal_hold

Enforcement note [Informative]

PEPs and release gates **MUST** block deployment or enable “degraded” only when **Critical/High** protocol non-conformances exist (e.g., TLS < 1.2, non-AEAD in TLS 1.2, missing mTLS where mandated).

NIST SP 800-160v2 linkage [Informative]

Evaluate & Maintain — evidence-driven verification of security mechanisms with continuous assurance.

Automation feasibility [Informative]

High: packet parsing, config linting, and standards mapping are automatable; risk exceptions/compensating controls require HITL.

Output Contracts (merged) [Informative]

OC-1: ProtocolComplianceReport [Informative]

- **Producer(s):** I4
- **Topic/Path:** sec.protocol.compliance (Kafka/AMQP) or POST /protocol/compliance/{mission_id}/reports
- **Schema/Format:** ProtocolComplianceReport@1.0 (endpoint, protocol, observed{version,cipher,kex,alpn,stapling,...}, expected_policy_ref, rules[], pass_rate, findings[], severity_max, remediation_summaries[], evidence_refs[], decision_rationale_url)
- **Classification:** C2
- **Delivery:** at-least-once
- **Ordering:** per-endpoint
- **Idempotency-Key:** sha256(endpoint, protocol, capture_window, config_digest)
- **Ack/Nack:** 202/201 ACK; 4xx/5xx NACK
- **Timeouts/Retry:** ack<=60s; exp-backoff<=5x; on persistent NACK open ticket and flag HITL
- **Side-Effects:** append to compliance ledger; update endpoint posture dashboard; notify owning team if severity_max >= High
- **HITL Token:** required to accept compensating controls or to waive Critical/High
- **Observability:** trace_id, mission_id, policy_refs, classification_label, provenance.attestation
- **Retention/TTL:** 3 years (or per regulatory/legal_hold)

Schema Capsule (OC-1) [Normative]

Requirement Level: Required

Condition: Always

schema_id=ProtocolComplianceReport@1.0 | json_schema_uri=uri://schema/protocol-compliance-report-1.0.json | sha256= | producers=I4 | consumers=SecDash-01, GRC-01, PRBot-01 | accepts=1.0–1.x

Conformance: This capsule and the corresponding MCP schema define testable requirements.

OC-2: ConfigPRComment [Informative]

- **Producer(s):** I4
- **Topic/Path:** POST /repos/{repo}/pulls/{pr}/comments or sec.protocol.pr_comments
- **Schema/Format:** ConfigPRComment@1.0 (pr_id, file_path, line_or_anchor, comment_text, rule_id, severity, suggested_patch, evidence_refs[])
- **Classification:** C1
- **Delivery:** at-least-once
- **Ordering:** per-pr_id
- **Idempotency-Key:** sha256(pr_id, file_path, line_or_anchor, comment_text_hash)
- **Ack/Nack:** 201 Created; retry/backoff on 5xx
- **Side-Effects:** links comment to report finding_id; updates PR checklist
- **HITL Token:** none (advisory; enforcement via gates)
- **Observability:** trace_id, mission_id, pr_id, rule_id
- **Retention/TTL:** repo policy

Schema Capsule (OC-2) [Normative]

Requirement Level: Conditionally Required

Condition: When infra repos accept inline comments or policy mandates in-PR guidance

schema_id=ConfigPRComment@1.0 | json_schema_uri=uri://schema/config-pr-comment-1.0.json | sha256= | producers=I4 | consumers=PRBot-01 | accepts=1.0–1.x

Conformance: Normative when condition is met.

OC-3: ProtocolFixTicket [Informative, optional]

- **Producer(s):** I4
- **Topic/Path:** sec.protocol.tickets (Jira/ServiceNow)
- **Schema/Format:** ProtocolFixTicket@1.0 (ticket_id, endpoint, protocol, severity, rule_ids[], due_by, suggested_patch_ref, links={report_id,evidence_refs[],prs[]})
- **Classification:** C2

- **Delivery/Ordering:** at-least-once; per-ticket_id
- **Idempotency-Key:** sha256(endpoint, protocol, rule_ids_hash, report_id)
- **Ack/Nack:** 201 Created; retry/backoff
- **Side-Effects:** assign to owning team; SLA tracking; waiver workflow if overdue
- **HITL Token:** required to close with compensating control accepted
- **Observability:** trace_id, mission_id, ticket_url
- **Retention/TTL:** per IRM policy (>= 1 year)

Schema Capsule (OC-3) [Normative]

Requirement Level: Optional

Condition: When tracked remediation is mandated

schema_id=ProtocolFixTicket@1.0 | json_schema_uri=uri://schema/protocol-fix-ticket-1.0.json | sha256= | producers=I4 | consumers=Jira-01, SNOW-01 | accepts=1.0–1.x

Conformance: Normative if implemented or claimed.

State machine (concise) [Informative]

states = { idle, ingesting_traces, parsing_configs, evaluating_rules, drafting_report, emitting_outputs, awaiting_HITL, failed, closed }

transition(idle -> ingesting_traces) when new captures arrive or scheduled scan triggers

transition(ingesting_traces -> parsing_configs) when min_traces_per_endpoint satisfied

transition(parsing_configs -> evaluating_rules) when config digests computed

transition(evaluating_rules -> drafting_report) when rule results finalized

transition(drafting_report -> emitting_outputs) when severity and mappings computed

transition(emitting_outputs -> awaiting_HITL) when compensating_control_requested or Critical/High waiver sought

transition(* -> failed) on schema/timeout/auth errors

idempotency_key = sha256(endpoint, protocol, capture_window, config_digest)

Output Contracts Summary [Normative]

Output Contract	Requirement Level	Trigger Condition	Business Impact
OC-1 ProtocolComplianceReport	Required	Always	Authoritative protocol posture

Output Contract	Requirement Level	Trigger Condition	Business Impact
OC-2 ConfigPRComment	Conditionally Required	PR platform supports comments or policy mandates in-PR guidance	In-context developer remediation
OC-3 ProtocolFixTicket	Optional	Tracked remediation required	Closure accountability and SLA tracking

Requirement Level Definitions:

- **Required:** Must be implemented for conformant deployment
- **Conditionally Required:** Must be implemented when trigger condition is met
- **Optional:** May be implemented for enhanced functionality

Policies and HITL gates [Informative]

- **policy_refs:** SP 800-52r2 (TLS), SP 800-77 (IPsec), SP 800-63 (auth), SP 800-131A (deprecation), SP 800-57 (crypto mgmt), FIPS 140-3 (modules), 800-53 SC/IA families.
- **HITL required:** accept compensating controls, approve exceptions for legacy endpoints, authorize auto-remediation in production.
- **Automatic HITL escalation triggers:** model_confidence < theta_low; severity_max >= High with production_readonly=true; endpoint serves data_class in {"pci","phi","pii"} and rule_fail_critical=true.
- **Manual outside agent:** certificate issuance/renewal; hardware or vendor stack upgrades.

SLOs and KPIs [Informative]

- ReportEmit_p95 <= 60 s from last trace/config ingestion
- FalsePositiveRate_30d <= 5 percent
- HighFindingMTTR_30d <= 7 days
- NonConformantEndpoints_rolling <= target set by policy

Outputs index [Informative]

[OC-1 ProtocolComplianceReport], [OC-2 ConfigPRComment], [OC-3 ProtocolFixTicket]

Technical Implementation Details (I4) [Informative]

Model and training profile [Informative]

model_id=protocol-verify-text-model; temperature=0.1; max_tokens_out=900
prompt_pack_id=protocol-compliance-v1 (standards profiles, platform snippets, few-shots)
RAG: sources={standards profiles, org policy allow/deny lists, prior reports, platform config library}; max_docs=10; min_similarity=0.78; citations required
fine_tuning/adapters: none initially; evaluate on precision/recall of rule violations and patch accuracy
guardrails: forbid secrets exfiltration; respect production_readonly; only propose diffs—never apply changes

Memory and state [Informative]

working_memory.max_tokens=4k; eviction=recency_then_importance
episodic_memory: per mission_id and endpoint journal (captures, configs, results); ttl=365d
semantic_memory: namespaces=["protocol-rules","platform-configs","prior-findings"]; embeddings=text-embedding-sec-v1; k=10
durable_state_store: append-only compliance ledger; snapshot at each report emission
consistency: at-least-once (events); exactly-once per idempotency_key for report storage
idempotency: as defined in Output Contracts

Decision and routing logic [Informative]

- **TLS example rules:**
fail_if protocol_version < TLS1.2
fail_if tls1.2 and cipher not in {TLS_ECDHE_ECDSA_WITH_AES_256_GCM_SHA384, TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384, TLS_CHACHA20_POLY1305_SHA256}
fail_if tls1.3 and suite not in {TLS_AES_256_GCM_SHA384, TLS_CHACHA20_POLY1305_SHA256}
warn_if ocsp_stapled=false and policy_requires_staple=true

- **SSH example rules:** deny diffie-hellman-group1-sha1; require ed25519 or rsa-sha2-512 hostkeys; restrict ciphers to chacha20-poly1305@openssh.com or aes256-gcm@openssh.com.
- **Severity computation:**

$$\text{severity_score} = 0.4\text{exploitability} + 0.3\text{data_class_weight} + 0.2\text{exposure_surface} + 0.1\text{compensating_control_absence}$$

$$\text{severity} = \text{map_to_bucket}(\text{severity_score})$$
- **Routing:** if severity_max >= High → emit OC-1; optionally OC-3; if repo context exists → also emit OC-2.

Model Risk Management [Informative]

continuous_validation: daily; suites=[goldens per protocol, adversarial traces (malleated JA3), noisy configs]

thresholds: eval_pass_rate >= 99.0 percent → auto_HITL if below

red_team_cycle: monthly tests (e.g., CBC downgrade, weak IKE suites)

rollback_policy: eval_drop >= 1.5 pp for 48 h → revert model_id; notify owners

Transparency and Audit Trail (Approver/Auditor UX) [Informative]

decision_rationale_template: endpoint, rule_id, observed vs expected, why_it_matters, control_refs, remediation_snippet, evidence_refs

UI/API: expose classification_label, provenance.attestation, decision_rationale_url

audit_log_format: JSONL with stable field order; retention per classification/legal_hold

Incident Response Integration [Informative]

If incident indicates protocol weakness, emit addendum reports targeting similar endpoints; seed PRs/tickets with mandatory diffs.

Change Impact Assessment [Informative]

When configs or runtime observations change, compute protocol_posture_delta and flag regressions; include link to prior report.

Stakeholder Feedback Loop [Informative]

Capture maintainer labels={accepted|deferred|false_positive}; use to tune rule exceptions (governance-approved); never suppress Critical class without HITL.

Data Sovereignty and Legal Hold [Informative]

classification default C2; legal_hold=true freezes purge for all reports and evidence_refs tied to regulated audits.

Interfaces (links only) [Informative]

Copyright © 2025 John M. Willis and Quantum Powered Security, Inc. • CC BY 4.0

Consumes: Traffic Captures; Service Configurations

Produces: OC-1 ProtocolComplianceReport; OC-2 ConfigPRComment; OC-3 ProtocolFixTicket

Safety and abuse prevention [Informative]

kill_switch on anomalous emission rate or secrets-like fields detected in configs; redact certificate private data; throttle PR/ticket creation.

Testing and validation [Informative]

contract tests for OC-1..OC-3; offline replay of PCAPs; mutation tests (cipher downgrades, stapling off); platform-specific lint baselines.

Deployment and lifecycle [Informative]

scale on capture volume; canary rules; SBOM and SLSA attestations; sign all outputs; regular profile updates (e.g., post-quantum transitions).

References / Standards [Informative]

NIST SP 800-52r2 (TLS); NIST SP 800-77 (IPsec); NIST SP 800-63 (Digital Identity); NIST SP 800-57 (Key Management); NIST SP 800-131A (Transitioning the Use of Cryptographic Algorithms); FIPS 140-3; NIST SP 800-160 Vol. 2; NIST SP 800-53 Rev. 5 (SC, IA); ISO/IEC 27002:2022.

MCP-Native Protocol Specification (I4) [Normative]

(Canonical schemas and validation live here; keep example payloads synchronized with the Agent Blueprint.)

- **Native Protocol(s) Consumed:** Traffic Captures (Zeek/tshark JSON); Service Configurations (Git/runtime)
- **Native Protocol(s) Produced:** ProtocolComplianceReport (events/REST); ConfigPRComment (PR APIs); ProtocolFixTicket (ticketing APIs)
- **MCP Context Fields:**
 - **Required:** mission_id; role="ProtocolComplianceAgent"; intent="verify"; policy_refs=[800-52r2, 800-77, 800-131A, FIPS 140-3, 800-63, 800-57]; provenance.attestation (SPIFFE + KID)
 - **Optional:** classification; decision_basis; constraints (production_readonly, min_traces_per_endpoint, no_auto_remediate); legal_hold

- **Enforcement Note:** PEPs and release gates MUST block or quarantine endpoints with Critical/High non-conformances until fixed or a HITL waiver is recorded.
- **Versioning and compatibility; producers/consumers registry:** authoritative in schema registry; see Schema Capsules for accepted ranges/EOL.
- **Example payloads:** native and MCP-wrapped examples above are authoritative.
- **Transparency hooks:** `classification_label`, `provenance.attestation`, `decision_rationale_url` available to downstream UIs/APIs.

Conformance: This section is **[Normative]** and, together with each **Schema Capsule**, defines testable requirements.

I5. Pattern Management Agent

Agent Blueprint [Informative]

Purpose: Curate, version, and publish reusable secure design patterns (e.g., internet-facing API gateway, token-based mTLS, privacy-preserving analytics). Continuously ingest RCA lessons and architecture review findings to create/update patterns and mark deprecations.

Operational Narrative [Informative]

Inputs used (authoritative sources):

- **RCA Lessons (DFIR/Postmortem Docs/REST):** root causes, control gaps, recommended mitigations, lessons learned, evidence links.
- **Architecture Review Findings (REST/Docs/Git):** issues, risks, control mappings, recommended patterns, supporting artifacts.

Model training / knowledge (what the LLM relies on):

- Prompt pack: pattern catalog rubric (acceptance criteria, anti-patterns, versioning rules, migration guidance).
- RAG sources: prior patterns with 800-53 mappings, RCA corpus, architecture review database, deprecation registry; never ingest regulated evidence directly—use `evidence_refs`.
- Guardrails: permitted repos/paths; change types limited to docs/manifest diffs unless explicit approval; no breaking change unless migration steps present.

Decisions it makes (deterministic + model-assisted):

- **Synthesis:** cluster signals from RCAs and reviews into candidate pattern deltas; map to controls and threat mitigations.
- **Versioning:** bump minor vs. major based on backward compatibility; create deprecation markers and EOL dates.
- **Applicability:** tag patterns with zones, data classes, stacks, and preconditions.
- **Migration guidance:** generate stepwise remediation and verification checks.
- **Governance:** route “requires_arch_board_approval” items for HITL; block publish if constraints violated.

Routing / where outputs go:

- **PatternUpdate** → event bus and registry; links to diffs, applicability matrix, migration guide.
- **Optional PRs** → pattern repo with Markdown/JSON updates and example snippets.
- **Optional DeprecationNotice** → broadcast to consuming teams and dashboards.

Automation scope vs. manual/HITL:

- Fully automated: ingestion, dedupe, control mapping, draft updates, applicability tagging, change-impact notes.
- **HITL required:** major version changes, deprecations with broad blast radius, policy exceptions, cross-domain pattern merges.
- Manual outside agent: executive approvals, vendor selection for reference implementations.

Security Domain: Security Architecture & Systems Engineering

Inputs (native protocols consumed) [Informative]

1. **RCA Lessons (DFIR/Postmortem REST)** — causal analysis and mitigations.
2. **Architecture Review Findings (REST/Docs/Git)** — issues, control mappings, recommended pattern adoptions.

Example: Consumed Protocol — RCA Lessons [Informative]

Native payload (RCA extract, JSON)

```
{
```

```
"rca_id": "RCA-2025-0815-0021",
"incident_id": "INC-45877",
"title": "Unauthorized lateral movement via weak east-west TLS",
"timeline": {
  "start": "2025-08-15T09:45:00Z",
  "detect": "2025-08-15T10:00:12Z",
  "contain": "2025-08-15T10:01:23Z"
},
"root_causes": [
  "Internal services allowed TLS 1.2 CBC suites without client auth",
  "No service identity pinning; shared cert reuse across tiers"
],
"contributing_factors": ["Legacy nginx images", "Config drift on east-west mesh"],
"control_gaps": ["SC-13 use of cryptography (weak mode)", "IA-3 device identification missing"],
"recommended_mitigations": [
  "Adopt mTLS with SPIFFE identities and TLS 1.3 AEAD-only",
  "Rotate per-service ECDSA keys; disallow cert sharing",
  "Enable policy enforcement at the mesh ingress"
],
"lessons_learned": [
  "Codify 'East-West mTLS with SPIFFE' as an enterprise pattern",
  "Add drift monitors on mesh TLS policy"
],
"attachments": [
  "uri://dfir/artifacts/pcap/inc-45877/flows",
  "uri://kb/dfir/lessons/RCA-2025-0815-0021"
```

```

],
  "published_at": "2025-08-16T12:00:00Z"
}
MCP-wrapped payload
{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-i5-patterns-1111-2222-3333-4444",
    "thread_id": "uuid-rca-RCA-2025-0815-0021",
    "task_id": "uuid-a1b2-c3d4-e5f6-7788",
    "role": "PatternManagementAgent",
    "intent": "curate",
    "policy_refs": ["PAT-APPROVED-USAGE", "SC-13", "IA-3", "SA-8"],
    "constraints":
["requires_arch_board_approval", "no_breaking_change_without_migration"],
    "decision_basis": {
      "evidence_refs": [
        "uri://dfir/rca/RCA-2025-0815-0021",
        "uri://dfir/artifacts/pcap/inc-45877/flows"
      ],
      "confidence": 0.93,
      "explanation_ref": "uri://kb/patterns/synthesis#rca-ingest"
    },
    "provenance": {
      "producer_spiffe": "spiffe://enterprise/arch/pattern-management-agent",
      "signing_kid": "kid-rca-i5-01",
      "attestation_ref": "uri://slsa/attestations/pattern-management@sha256:rca01"
    }
  }
}

```

```

    },
    "classification": "C2",
    "legal_hold": false
  },
  "native_payload": { "...": "..." }
}

```

Example: Consumed Protocol — Architecture Review Findings [Informative]

Native payload (ArchReviewFindings excerpt)

```

{
  "review_id": "AR-2025-07-PAY-01",
  "system": "Payments API",
  "version": "v1.4",
  "findings": [
    {
      "id": "AR-NET-001",
      "severity": "High",
      "control_map": ["SC-7", "SC-8", "SC-13"],
      "issue": "Edge TLS termination lacks HSTS and OCSP stapling",
      "recommendation": "Adopt 'Zero-Trust Edge Gateway (TLS 1.3 + HSTS + OCSP stapling)' pattern"
    },
    {
      "id": "AR-AUTH-004",
      "severity": "Medium",
      "control_map": ["IA-2", "AC-7"],
      "issue": "Missing adaptive MFA for admin console",
      "recommendation": "Adopt 'Adaptive MFA with device posture' pattern"
    }
  ]
}

```

```

    }
  ],
  "artifacts": [
    "uri://git/arch/payments/diagrams/payments.puml@b17a53f",
    "uri://idp/policy/snapshots/2025-07-21"
  ],
  "reviewed_at": "2025-07-22T18:30:00Z"
}
MCP-wrapped payload
{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-i5-patterns-1111-2222-3333-4444",
    "thread_id": "uuid-archreview-AR-2025-07-PAY-01",
    "task_id": "uuid-99aa-bbcc-ddee-ff00",
    "role": "PatternManagementAgent",
    "intent": "curate",
    "policy_refs": ["PAT-APPROVED-USAGE", "SC-7", "SC-8", "SC-13", "IA-2", "AC-7"],
    "constraints": ["requires_arch_board_approval"],
    "decision_basis": {
      "evidence_refs": [
        "uri://arch/reviews/AR-2025-07-PAY-01",
        "uri://git/arch/payments/diagrams/payments.puml@b17a53f"
      ],
      "confidence": 0.95,
      "explanation_ref": "uri://kb/patterns/curation#arch-review-signal"
    }
  },

```

```

"provenance": {
  "producer_spiffe": "spiffe://enterprise/arch/pattern-management-agent",
  "signing_kid": "kid-arch-i5-02",
  "attestation_ref": "uri://slsa/attestations/pattern-management@sha256:arch02"
},
"classification": "C2",
"legal_hold": false
},
"native_payload": { "...": "..." }
}

```

Outputs (native) [Informative]

- **PatternUpdate** (version, diffs, applicability, migration guidance).
- **Optional: PatternRepoPR** to pattern repo; **DeprecationNotice** for outdated patterns.

MCP context (required) [Informative]

mission_id; role="PatternManagementAgent"; intent="curate"; policy_refs (approved-usage policy IDs; 800-53 mapping for the pattern); provenance (SPIFFE ID, signing KID, attestation)

MCP context (optional) [Informative]

classification (usually C2); decision_basis (evidence_refs, confidence, explanation_ref); constraints (e.g., requires_arch_board_approval, no_breaking_change_without_migration); legal_hold

Enforcement note [Informative]

PEPs in pattern registry and CI status checks **MUST** reject pattern updates that introduce breaking changes without a migration plan or required approvals; deprecations **MUST** publish EOL dates and replacement patterns.

NIST SP 800-160v2 linkage [Informative]

Design → Implement → Evaluate → Maintain — institutionalize learning via pattern libraries with evidence-backed improvements.

Automation feasibility [Informative]

Copyright © 2025 John M. Willis and Quantum Powered Security, Inc. • CC BY 4.0

High: ingestion, dedupe, control-mapping, applicability tagging, and PR generation are automatable; approvals are HITL.

Output Contracts (merged) [Informative]

OC-1: PatternUpdate [Informative]

- **Producer(s):** I5
- **Topic/Path:** sec.patterns.update (Kafka/AMQP) and POST /patterns/{pattern_id}/versions
- **Schema/Format:** PatternUpdate@1.0 (pattern_id, version, change_type, diffs[], controls_map[], applicability{zones,data_classes,stacks}, migration_steps[], references{rca_ids[], review_ids[]}, deprecation{replaces?, replaced_by?}, rationale_url, evidence_refs[])
- **Classification:** C2
- **Delivery:** at-least-once
- **Ordering:** per-pattern_id
- **Idempotency-Key:** sha256(pattern_id, version)
- **Ack/Nack:** 201/202 ACK; 4xx/5xx NACK
- **Timeouts/Retry:** ack<=60s; retry<=5x; on persistent NACK open governance ticket
- **Side-Effects:** update pattern registry index; notify subscribers; attach controls_map to GRC
- **HITL Token:** required when change_type is major or when constraints demand approval
- **Observability:** trace_id, mission_id, policy_refs, classification_label, provenance.attestation
- **Retention/TTL:** 7 years

Schema Capsule (OC-1) [Normative]

Requirement Level: Required

Condition: Always

schema_id=PatternUpdate@1.0 | json_schema_uri=uri://schema/pattern-update-1.0.json | sha256= | producers=I5 | consumers=PatternRegistry-01, GRC-01, Notify-01 | accepts=1.0–1.x

Conformance: This capsule and the corresponding MCP schema define testable requirements.

OC-2: PatternRepoPR [Informative]

- **Producer(s):** I5
- **Topic/Path:** POST /repos/{repo}/pulls and commits to patterns/ directory
- **Schema/Format:** PatternRepoPR@1.0 (repo, branch, pr_title, pr_body, files_changed[], diffs[], reviewers[], links{pattern_update_id, evidence_refs[]})
- **Classification:** C1
- **Delivery:** at-least-once
- **Ordering:** per-repo
- **Idempotency-Key:** sha256(repo, branch, pr_title_hash)
- **Ack/Nack:** 201 Created; retry/backoff on 5xx
- **Side-Effects:** triggers CI lint of pattern manifests; links PR to PatternUpdate
- **HITL Token:** required if change_type is major or repo requires board approval
- **Observability:** trace_id, mission_id, repo, pr_id
- **Retention/TTL:** repo policy

Schema Capsule (OC-2) [Normative]

Requirement Level: Conditionally Required

Condition: When patterns are Git-managed and PR workflow is mandated
schema_id=PatternRepoPR@1.0 | json_schema_uri=uri://schema/pattern-repo-pr-1.0.json | sha256= | producers=I5 | consumers=PRBot-01, CI-Lint-01 | accepts=1.0–1.x

Conformance: Normative when condition is met.

OC-3: DeprecationNotice [Informative]

- **Producer(s):** I5
- **Topic/Path:** sec.patterns.deprecation and registry notices
- **Schema/Format:** DeprecationNotice@1.0 (pattern_id, replaced_by, reason, effective_date, eol_date, required_actions[], impact_scope, evidence_refs[])
- **Classification:** C2

- **Delivery:** at-least-once
- **Ordering:** per-pattern_id
- **Idempotency-Key:** sha256(pattern_id, eol_date)
- **Ack/Nack:** 201/202 ACK; retry/backoff
- **Side-Effects:** notify owning teams; create migration tasks for active adopters
- **HITL Token:** required to finalize EOL for widely adopted patterns
- **Observability:** trace_id, mission_id, pattern_id, impact_scope
- **Retention/TTL:** 3 years after EOL

Schema Capsule (OC-3) [Normative]

Requirement Level: Optional

Condition: When pattern deprecations are practiced or required by policy

schema_id=DeprecationNotice@1.0 | json_schema_uri=uri://schema/pattern-deprecation-1.0.json | sha256= | producers=I5 | consumers=PatternRegistry-01, Notify-01, PM-Backlog-01 | accepts=1.0–1.x

Conformance: Normative if implemented or claimed.

State machine (concise) [Informative]

```
states = { idle, ingesting_rca, ingesting_reviews, synthesizing_deltas,
validating_controls, drafting_update, awaiting_HITL, publishing, notifying, failed, closed
}
```

```
transition(idle -> ingesting_rca) when new RCA published
```

```
transition(ingesting_rca -> ingesting_reviews) when correlated systems found
```

```
transition(ingesting_reviews -> synthesizing_deltas) when evidence thresholds met
```

```
transition(synthesizing_deltas -> validating_controls) when candidate changes mapped
to controls
```

```
transition(validating_controls -> drafting_update) when compatibility and constraints
analyzed
```

```
transition(drafting_update -> awaiting_HITL) when change_type is major or constraints
require approval
```

```
transition(drafting_update -> publishing) when minor and policy allows auto-publish
```

```
transition(publishing -> notifying) after OC emissions succeed
```

```
transition(* -> failed) on schema/timeout/auth errors
```

```
idempotency_key = sha256(pattern_id, version)
```

Output Contracts Summary [Normative]

Output Contract	Requirement Level	Trigger Condition	Business Impact
OC-1 PatternUpdate	Required	Always	Authoritative pattern lifecycle updates
OC-2 PatternRepoPR	Conditionally Required	Patterns are Git-managed and PR workflow is mandated	Reviewable, auditable change vehicle
OC-3 DeprecationNotice	Optional	Deprecation lifecycle is in use	Safe retirement and guided migrations

Requirement Level Definitions:

- **Required:** Must be implemented for conformant deployment
- **Conditionally Required:** Must be implemented when trigger condition is met
- **Optional:** May be implemented for enhanced functionality

Policies and HITL gates [Informative]

- **policy_refs:** PAT-APPROVED-USAGE; 800-53 mappings per pattern (e.g., SC-7, SC-8, SC-13, IA-2, AC-7, SA-8).
- **HITL required:** change_type = major; broad blast radius; deprecations with high adoption; exceptions to approved usage.
- **Automatic HITL escalation triggers:** model_confidence < theta_low; conflicting RCA vs. review signals; migration_coverage < threshold.
- **Manual outside agent:** cross-program alignment and executive approvals.

SLOs and KPIs [Informative]

- PatternUpdatePublish_p95 <= 60 s after inputs stabilized
- FalseChangeRate_30d <= 2 percent
- DeprecationAdoption90d >= 80 percent for affected services
- RCA_to_PatternDelta_MTTD <= 24 h

Outputs index [Informative]

Technical Implementation Details (I5) [Informative]

Model and training profile [Informative]

model_id=pattern-curation-text-model; temperature=0.1; max_tokens_out=900
prompt_pack_id=pattern-management-v1 (pattern rubric, versioning rules, migration templates, few-shots)

RAG: sources={pattern catalog, RCA corpus, arch review DB, deprecation registry, GRC control maps}; max_docs=12; min_similarity=0.78; citations required
fine_tuning/adapters: none initially; evaluate on mapping accuracy and change safety
guardrails: forbid code execution; restrict write scopes to pattern repos and registry APIs; enforce migration presence on breaking changes

Memory and state [Informative]

working_memory.max_tokens=4k; eviction=recency_then_importance
episodic_memory: per pattern_id journal of changes and decisions; ttl=365d
semantic_memory: namespaces=["patterns","rca-signals","arch-findings"];
embeddings=text-embedding-sec-v1; k=12
durable_state_store: event-sourced ledger; snapshot each published version
consistency: at-least-once (OC-1..OC-3)
idempotency: as defined in Output Contracts

Decision and routing logic [Informative]

- **Change classification:**
change_type = major if compatibility_break=true or required_controls_set changes; else minor.
- **Applicability tagging:**
zones $\in$ {dmz, prod, corp}; data_classes derived from inputs; stacks from artifacts.
- **Priority score (publish ordering):**
 $priority = 0.5adoption_count_weight + 0.3severity_weight + 0.2*incident_recency_weight$.

Model Risk Management [Informative]

continuous_validation: daily; suites=[goldens, contradictory-signal sets, migration-absent proposals]
thresholds: eval_pass_rate $\geq$ 99.0 percent $\rightarrow$ auto_HITL if below

red_team_cycle: monthly tests for risky deprecations and mis-mappings
rollback_policy: eval_drop >= 1.5 percentage points for 48 h → revert model_id; notify owners

Transparency and Audit Trail (Approver/Auditor UX) [Informative]

decision_rationale_template: source_signals, control_mappings, compatibility assessment, migration steps, references
UI/API: expose classification_label, provenance.attestation, decision_rationale_url
audit_log_format: JSONL with stable field order; retention per classification and legal_hold

Incident Response Integration [Informative]

When IR identifies systemic weaknesses, auto-seed candidate pattern deltas; link PatternUpdate to incident and RCA ids.

Change Impact Assessment [Informative]

Compute adoption_impact set and migration effort estimates; include in OC-1 and PR body.

Stakeholder Feedback Loop [Informative]

Accept maintainer labels={useful|noise|risky|needs_more_guidance}; feed into rubric after governance review; never auto-train on regulated evidence.

Data Sovereignty and Legal Hold [Informative]

classification default C2; legal_hold=true preserves OC snapshots beyond standard TTL and freezes purge.

Interfaces (links only) [Informative]

Consumes: RCA Lessons; Architecture Review Findings
Produces: OC-1 PatternUpdate; OC-2 PatternRepoPR; OC-3 DeprecationNotice

Safety and abuse prevention [Informative]

kill_switch on surge of major changes; block publishing without migration for breaking updates; throttle notifications.

Testing and validation [Informative]

contract tests for OC-1..OC-3; replay of historical RCAs and reviews; mutation tests for deprecation flows; schema validation and signer attestation checks.

Deployment and lifecycle [Informative]

scale on input volume; canary publishes to staging registry; SBOM and SLSA attestations; sign all outputs; periodic rubric refresh.

References / Standards [Informative]

NIST SP 800-160 Vol. 2; NIST SP 800-53 Rev. 5 (SC, SA, IA, AC); NIST SP 800-63; NIST SP 800-57; NIST SP 800-131A; ISO/IEC 27002:2022; CIS Controls v8.

MCP-Native Protocol Specification (I5) [Normative]

(Canonical schemas and validation live here; keep example payloads synchronized with the Agent Blueprint.)

- **Native Protocol(s) Consumed:** RCA Lessons (DFIR/Postmortem REST); Architecture Review Findings (REST/Docs/Git)
- **Native Protocol(s) Produced:** PatternUpdate (events/REST); PatternRepoPR (PR APIs); DeprecationNotice (events/registry)
- **MCP Context Fields:**
 - **Required:** mission_id; role="PatternManagementAgent"; intent="curate"; policy_refs=[approved-usage IDs and 800-53 mappings]; provenance.attestation (SPIFFE + KID)
 - **Optional:** classification; decision_basis; constraints=["requires_arch_board_approval","no_breaking_change_without_migration"]; legal_hold
- **Enforcement Note:** Registries and CI MUST reject pattern changes violating constraints or lacking migration for breaking updates; deprecations MUST include effective and EOL dates.
- **Versioning and compatibility; producers/consumers registry:** authoritative in schema registry; see Schema Capsules for accepted ranges/EOL.
- **Example payloads:** native and MCP-wrapped examples above are authoritative.
- **Transparency hooks:** classification_label, provenance.attestation, decision_rationale_url exposed to downstream UIs/APIs.

Conformance: This section is **[Normative]** and, together with each **Schema Capsule**, defines testable requirements.

I6. DevSecOps Pipeline Agent

Agent Blueprint [Informative]

Purpose: Enforce security gates in CI/CD by ingesting build events and scanner outputs; decide pass/fail and remediation requirements; block merges/releases when constraints are violated; publish **PipelineGateResult**.

Operational Narrative [Informative]

Inputs used (authoritative sources):

- **CI/CD Build Events (GitHub/GitLab/ADO webhooks):** workflow status, branch/commit, initiator, unit-test coverage, artifact URIs.
- **SAST (SARIF):** rule id, file/line, CWE, severity and count.
- **SCA/Dependency Scan (CycloneDX + vuln JSON):** component inventory, CVEs with severities/fixes.
- **IaC Scan (Checkov/tfsec JSON):** misconfig findings with severities, resources, guidelines.
- **Container Image Scan (Trivy/Anchore JSON):** package list and CVEs by image; fixed versions.

Model training / knowledge (what the LLM relies on):

- Prompt pack: gating rubric (org thresholds), normalization of scanner severities, remediation templates for PR comments and tickets.
- RAG sources: policy catalog (e.g., “no_merge_if” rules), historical gate decisions, exceptions registry, vulnerability advisories; never ingest raw secrets—only evidence_refs.
- Guardrails: read-only to source; write-scopes limited to status checks and advisory comments unless policy enables auto-fix PRs.

Decisions it makes (deterministic + model-assisted):

- **Gate evaluation:** compute per-signal pass/fail and overall decision; determine **merge** and **release** blocks.
- **Prioritization:** rank remediations by exploitability, reachability, fix availability, and blast radius.
- **Exception routing:** detect policy conflicts or compensating controls; raise HITL approval where required.

- **Change advice:** generate minimal-diff PR hints (e.g., version bump, IaC stanza fixes).

Routing / where outputs go:

- **PipelineGateResult** → event bus/REST; consumed by dashboards, GRC, and orchestrators.
- **PR/MR Status Checks** → Git providers (required checks).
- **Release Gate Decisions** → deployment orchestrators (block/unblock).
- **Optional** inline annotations/comments on PRs with specific fixes.

Automation scope vs. manual/HITL:

- Fully automated: ingest, normalize, evaluate, publish results, set status checks, set release gates.
- **HITL required:** approve waivers/exceptions; override Critical/High blocks; accept compensating controls for time-limited releases.
- Manual outside agent: deep refactors, vendor upgrades that exceed auto-fix scope.

Security Domain: Security Architecture & Systems Engineering

Inputs (native protocols consumed) [Informative]

1. **CI/CD Build Events (GitHub/GitLab/ADO webhooks)** — workflow outcome, coverage, artifact links.
2. **SAST Results (SARIF 2.1.0 JSON)** — code vulnerabilities.
3. **SCA/Dependency Scan (CycloneDX + vuln JSON)** — vulnerable components.
4. **IaC Scan (Checkov/tfsec JSON)** — misconfigurations.
5. **Container Image Scan (Trivy/Anchore JSON)** — image CVEs and policies.

Example: Consumed Protocol — CI/CD Build Events [Informative]

Native payload (GitHub Actions workflow run)

```
{
  "workflow_run_id": 4182271,
  "repo": "payments/service-api",
```

```

"branch": "main",
"commit": "b17a53f",
"initiator": "dev.alex",
"status": "completed",
"conclusion": "success",
"checks": {
  "unit": {"status": "pass", "coverage_pct": 83.4},
  "build": {"status": "pass"}
},
"artifacts": [
  "uri://ci/artifacts/sast/b17a53f.sarif",
  "uri://ci/artifacts/sca/b17a53f.cdx.json",
  "uri://ci/artifacts/iac/b17a53f.checkov.json",
  "uri://ci/artifacts/image/trivy-report-b17a53f.json"
],
"ended_at": "2025-08-15T14:20:31Z"
}

```

MCP-wrapped payload

```

{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-i6-pipe-1111-2222-3333-4444",
    "thread_id": "uuid-ci-payments-service-api@b17a53f",
    "task_id": "uuid-eee5-fff6-1111-2222",
    "role": "DevSecOpsPipelineAgent",
    "intent": "assure",
    "policy_refs": ["SA-11", "RA-5", "CM-6"],

```

```

"constraints": ["min_coverage:80","block_release_if_failed_gates"],
"decision_basis": {
  "evidence_refs": [
    "uri://github/actions/workflow_runs/4182271",
    "uri://ci/artifacts/coverage/b17a53f.json"
  ],
  "confidence": 0.97,
  "explanation_ref": "uri://kb/devsecops/gates/build-metadata-eval"
},
"provenance": {
  "producer_spiffe": "spiffe://enterprise/sase/devsecops-pipeline-agent",
  "signing_kid": "kid-ci-i6-01",
  "attestation_ref": "uri://slsa/attestations/devsecops@sha256:ci01"
},
"classification": "C2",
"legal_hold": false
},
"native_payload": { "...": "..." }
}

```

Example: Consumed Protocol — SAST (SARIF 2.1.0) [Informative]

Native payload (excerpt)

```

{
  "version": "2.1.0",
  "runs": [{
    "tool": {"driver": {"name": "CodeQL", "semanticVersion": "2.16.4"}},
    "results": [{
      "ruleId": "js/path-traversal",

```

```

    "level": "error",
    "message": {"text": "Unsanitized user input used in file path."},
    "locations": [{"physicalLocation": {"artifactLocation": {"uri": "routes/files.js"}, "region": {"startLine": 87}}}],
    "properties": {"severity": "HIGH", "cwe": "CWE-22"}
  }}
}

```

MCP-wrapped payload

```

{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-i6-pipe-1111-2222-3333-4444",
    "thread_id": "uuid-sast-b17a53f",
    "task_id": "uuid-aa11-bb22-cc33-dd44",
    "role": "DevSecOpsPipelineAgent",
    "intent": "assure",
    "policy_refs": ["SA-11", "RA-5"],
    "constraints": ["no_merge_if:{sast.high>0}"],
    "decision_basis": {
      "evidence_refs": ["uri://ci/artifacts/sast/b17a53f.sarif"],
      "confidence": 0.98,
      "explanation_ref": "uri://kb/devsecops/gates/sast-thresholds"
    },
    "provenance": {
      "producer_spiffe": "spiffe://enterprise/sase/devsecops-pipeline-agent",
      "signing_kid": "kid-sast-i6-02",

```

```

    "attestation_ref": "uri://slsa/attestations/devsecops@sha256:sast02"
  },
  "classification": "C2",
  "legal_hold": false
},
"native_payload": { "...": "..." }
}

```

Example: Consumed Protocol — SCA (CycloneDX) [Informative]

Native payload (with vuln extension)

```

{
  "bomFormat": "CycloneDX",
  "specVersion": "1.5",
  "version": 1,
  "components": [
    { "name": "express", "version": "4.18.2", "purl": "pkg:npm/express@4.18.2" },
    { "name": "minimatch", "version": "3.0.4", "purl": "pkg:npm/minimatch@3.0.4" }
  ],
  "vulnerabilities": [
    { "id": "CVE-2024-1234", "affects": [ { "ref": "pkg:npm/minimatch@3.0.4" } ],
      "ratings": [ { "severity": "CRITICAL", "score": 9.8 } ]
    }
  ]
}

```

MCP-wrapped payload

```

{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-i6-pipe-1111-2222-3333-4444",

```

```

"thread_id": "uuid-sca-b17a53f",
"task_id": "uuid-4411-5522-6633-7744",
"role": "DevSecOpsPipelineAgent",
"intent": "assure",
"policy_refs": ["RA-5", "CM-6"],
"constraints": ["no_merge_if:{sca.critical>0}"],
"decision_basis": {
  "evidence_refs": ["uri://ci/artifacts/sca/b17a53f.cdx.json"],
  "confidence": 0.96,
  "explanation_ref": "uri://kb/devsecops/gates/sca-critical-block"
},
"provenance": {
  "producer_spiffe": "spiffe://enterprise/sase/devsecops-pipeline-agent",
  "signing_kid": "kid-sca-i6-03",
  "attestation_ref": "uri://slsa/attestations/devsecops@sha256:sca03"
},
"classification": "C2",
"legal_hold": false
},
"native_payload": { "...": "..." }
}

```

Example: Consumed Protocol — IaC Scan (Checkov) [Informative]

Native payload

```

{
  "report_type": "terraform",
  "summary": {"failed": 2, "passed": 35, "skipped": 3},
  "results": [

```

```
{
  "check_id": "CKV_AWS_20",
  "check_name": "S3 bucket is not publicly accessible",
  "file_path": "/infra/s3.tf",
  "resource": "aws_s3_bucket.logs",
  "severity": "HIGH",
  "guideline": "https://docs.example.com/CKV_AWS_20"
},
{
  "check_id": "CKV_AWS_18",
  "check_name": "Ensure CloudTrail log file validation is enabled",
  "file_path": "/infra/cloudtrail.tf",
  "resource": "aws_cloudtrail.org",
  "severity": "MEDIUM"
}
]
```

MCP-wrapped payload

```
{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-i6-pipe-1111-2222-3333-4444",
    "thread_id": "uuid-iac-b17a53f",
    "task_id": "uuid-5511-6622-7733-8844",
    "role": "DevSecOpsPipelineAgent",
    "intent": "assure",
    "policy_refs": ["CM-6", "RA-5", "SC-7"],
```

```

"constraints": [{"no_merge_if":{"iac.high>0"}},
"decision_basis": {
  "evidence_refs": [{"uri://ci/artifacts/iac/b17a53f.checkov.json"}],
  "confidence": 0.95,
  "explanation_ref": "uri://kb/devsecops/gates/iac-misconfig"
},
"provenance": {
  "producer_spiffe": "spiffe://enterprise/sase/devsecops-pipeline-agent",
  "signing_kid": "kid-iac-i6-04",
  "attestation_ref": "uri://slsa/attestations/devsecops@sha256:iac04"
},
"classification": "C2",
"legal_hold": false
},
"native_payload": { "...": "..." }
}

```

Example: Consumed Protocol — Container Image Scan (Trivy) [Informative]

Native payload

```

{
  "ArtifactName": "svc-api:1.4.0-b17a53f",
  "ArtifactType": "container_image",
  "Results": [{
    "Target": "alpine:3.19",
    "Type": "os",
    "Vulnerabilities": [
      {"VulnerabilityID": "CVE-2025-12345", "PkgName": "busybox", "InstalledVersion":
"1.36.1-r2", "FixedVersion": "1.36.1-r3", "Severity": "CRITICAL"}
    ]
  }]
}

```

```

    ]
  }}
}
MCP-wrapped payload
{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-i6-pipe-1111-2222-3333-4444",
    "thread_id": "uuid-image-b17a53f",
    "task_id": "uuid-7711-8822-9933-0044",
    "role": "DevSecOpsPipelineAgent",
    "intent": "assure",
    "policy_refs": ["RA-5", "CM-6"],
    "constraints": ["no_release_if:{image.critical>0}"],
    "decision_basis": {
      "evidence_refs": ["uri://ci/artifacts/image/trivy-report-b17a53f.json"],
      "confidence": 0.96,
      "explanation_ref": "uri://kb/devsecops/gates/image-vuln-policy"
    },
    "provenance": {
      "producer_spiffe": "spiffe://enterprise/sase/devsecops-pipeline-agent",
      "signing_kid": "kid-image-i6-05",
      "attestation_ref": "uri://slsa/attestations/devsecops@sha256:image05"
    },
    "classification": "C2",
    "legal_hold": false
  },

```

```
"native_payload": { "...": "..." }  
}
```

Outputs (native) [Informative]

- **PipelineGateResult** (overall pass/fail; blocks and reasons; prioritized remediations).
- **PR/MR Status Checks** (required checks set to success/failure).
- **Release Gate Decisions** (block/unblock to orchestrators).

MCP context (required) [Informative]

mission_id; role="DevSecOpsPipelineAgent"; intent="assure"; policy_refs (SA-11, RA-5, CM-6; org pipeline policy IDs); constraints (e.g., no_merge_if:{...}, min_coverage:80, block_release_if_failed_gates); provenance (SPIFFE ID, signing KID, attestation)

MCP context (optional) [Informative]

classification (usually C2); decision_basis (evidence_refs, confidence, explanation_ref); legal_hold

Enforcement note [Informative]

PEPs in Git and release orchestrators MUST honor blocking status when constraints are violated; waivers require signed HITL tokens with scope and expiry.

NIST SP 800-160v2 linkage [Informative]

Implement → Evaluate → Maintain — evidence-driven engineering gates (also aligns to NIST SP 800-53 SA-11, RA-5, CM-6).

Automation feasibility [Informative]

High: gate logic is fully automatable; only exceptions/waivers require HITL.

Output Contracts (merged) [Informative]

OC-1: PipelineGateResult [Informative]

- **Producer(s)**: I6
- **Topic/Path**: sec.pipeline.gate_result (Kafka/AMQP) or POST /pipeline/{run_id}/gate_result
- **Schema/Format**: PipelineGateResult@1.0 (run_id, repo, branch, commit, gate_version, decisions{merge,release}, status{PASS|FAIL|WARN}, reasons[],

metrics{coverage_pct, sast.high, sca.critical, iac.high, image.critical, secrets},
remediation_hints[], evidence_refs[], constraints_applied[], waiver_ref?)

- **Classification:** C2
- **Delivery:** at-least-once
- **Ordering:** per-run_id
- **Idempotency-Key:** sha256(run_id, commit, gate_version)
- **Ack/Nack:** 201/202 ACK; 4xx/5xx NACK
- **Timeouts/Retry:** ack<=60s; retry<=5x; open ticket on persistent NACK
- **Side-Effects:** update gate dashboard; notify PR/MR; propagate to GRC evidence store
- **HITL Token:** required to override FAIL to TEMP_ALLOW (time-bound)
- **Observability:** trace_id, mission_id, policy_refs, classification_label, provenance.attestation
- **Retention/TTL:** 3 years (or legal_hold)

Schema Capsule (OC-1) [Normative]

Requirement Level: Required

Condition: Always

schema_id=PipelineGateResult@1.0 | json_schema_uri=uri://schema/pipeline-gate-result-1.0.json | sha256= | producers=l6 | consumers=GateDash-01, GRC-01, Orchestrator-01 | accepts=1.0–1.x

Conformance: This capsule and the corresponding MCP schema define testable requirements.

OC-2: PRStatusCheck [Informative]

- **Producer(s):** l6
- **Topic/Path:** POST /repos/{repo}/statuses/{commit} or Graph API status checks
- **Schema/Format:** PRStatusCheck@1.0 (repo, pr_id, commit, context="security-gates", state={success|failure|pending}, target_url, description, reasons[], evidence_refs[], constraints_applied[])
- **Classification:** C1
- **Delivery:** at-least-once

- **Ordering:** per-pr_id
- **Idempotency-Key:** sha256(pr_id, commit, context)
- **Ack/Nack:** 201 Created; retry/backoff
- **Side-Effects:** gate enforcement via required checks
- **HITL Token:** none (HITL applies to waiver, not to setting status)
- **Observability:** trace_id, mission_id, pr_id, commit
- **Retention/TTL:** repo policy

Schema Capsule (OC-2) [Normative]

Requirement Level: Conditionally Required

Condition: When PR/MR required checks are used in the org
 schema_id=PRStatusCheck@1.0 | json_schema_uri=uri://schema/pr-status-check-1.0.json | sha256= | producers=l6 | consumers=GitHub-Checks-01, GitLab-Checks-01 | accepts=1.0–1.x

Conformance: Normative when condition is met.

OC-3: ReleaseGateDecision [Informative]

- **Producer(s):** l6
- **Topic/Path:** sec.pipeline.release_gate (events) or POST /orchestrators/{env}/gates/{run_id}
- **Schema/Format:** ReleaseGateDecision@1.0 (run_id, env, decision={BLOCK|ALLOW|TEMP_ALLOW}, expiry_ts?, reasons[], waiver_ref?, evidence_refs[])
- **Classification:** C2
- **Delivery:** exactly-once (consumer enforces)
- **Ordering:** per-env, per-run_id
- **Idempotency-Key:** sha256(run_id, env, decision, expiry_floor_60s)
- **Ack/Nack:** orchestration ACK<=30s; retry/backoff
- **Side-Effects:** halt or continue deployment; append to audit log
- **HITL Token:** required for TEMP_ALLOW or ALLOW when constraints failed
- **Observability:** trace_id, mission_id, env, reasons

- **Retention/TTL:** 3 years

Schema Capsule (OC-3) [Normative]

Requirement Level: Conditionally Required

Condition: When deployments use orchestrator gates

schema_id=ReleaseGateDecision@1.0 | json_schema_uri=uri://schema/release-gate-decision-1.0.json | sha256= | producers=l6 | consumers=Orchestrator-01 | accepts=1.0–1.x

Conformance: Normative when condition is met.

OC-4: FindingAnnotation [Informative, optional]

- **Producer(s):** l6
- **Topic/Path:** POST /repos/{repo}/pulls/{pr}/comments or sec.pipeline.annotations
- **Schema/Format:** FindingAnnotation@1.0 (pr_id, file_path, line, rule_id, severity, message, suggested_patch?, evidence_ref)
- **Classification:** C1
- **Delivery/Ordering:** at-least-once; per-pr_id
- **Idempotency-Key:** sha256(pr_id, file_path, line, rule_id)
- **Ack/Nack:** 201 Created; retry/backoff
- **Side-Effects:** developer guidance; links back to PipelineGateResult
- **HITL Token:** none
- **Observability:** trace_id, mission_id, pr_id
- **Retention/TTL:** repo policy

Schema Capsule (OC-4) [Normative]

Requirement Level: Optional

Condition: When inline annotations are enabled

schema_id=FindingAnnotation@1.0 | json_schema_uri=uri://schema/finding-annotation-1.0.json | sha256= | producers=l6 | consumers=PRBot-01 | accepts=1.0–1.x

Conformance: Normative if implemented or claimed.

State machine (concise) [Informative]

states = { idle, ingesting_events, normalizing_findings, evaluating_gates,
 emitting_results, enforcing_checks, awaiting_HITL, failed, closed }
 transition(idle -> ingesting_events) when build completes or artifacts available
 transition(ingesting_events -> normalizing_findings) when all required artifacts fetched
 transition(normalizing_findings -> evaluating_gates) when metrics computed
 transition(evaluating_gates -> emitting_results) when decision derived
 transition(emitting_results -> enforcing_checks) after OC-1 emitted
 transition(enforcing_checks -> awaiting_HITL) when constraints violated and waiver
 requested
 transition(* -> failed) on schema/timeout/auth errors
 idempotency_key = sha256(run_id, commit, gate_version)

Output Contracts Summary [Normative]

Output Contract	Requirement Level	Trigger Condition	Business Impact
OC-1 PipelineGateResult	Required	Always	Authoritative gate decision
OC-2 PRStatusCheck	Conditionally Required	Org uses PR/MR required checks	Enforced merge policy
OC-3 ReleaseGateDecision	Conditionally Required	Deployments gated by orchestrators	Enforced release policy
OC-4 FindingAnnotation	Optional	Inline annotations enabled	Faster developer remediation

Requirement Level Definitions:

- **Required:** Must be implemented for conformant deployment
- **Conditionally Required:** Must be implemented when trigger condition is met
- **Optional:** May be implemented for enhanced functionality

Policies and HITL gates [Informative]

- policy_refs: SA-11 (developer testing), RA-5 (vuln scanning), CM-6 (baseline/safeguards), plus org pipeline policies.

- **HITL required:** to approve waivers that contradict no_merge_if or no_release_if constraints; to accept compensating controls; to set TEMP_ALLOW with expiry.
- **Automatic HITL escalation triggers:** model_confidence < theta_low; conflicting scanner signals; severity_max >= High with public exposure; secrets detected.
- **Manual outside agent:** multi-repo refactors, dependency upgrades impacting ABI.

SLOs and KPIs [Informative]

- GateDecisionEmit_p95 <= 30 s after last artifact ingested
- FalseBlockRate_30d <= 2 percent
- CriticalToFixMTTR_14d <= org target
- WaiverExpiryCompliance >= 98 percent

Outputs index [Informative]

[OC-1 PipelineGateResult], [OC-2 PRStatusCheck], [OC-3 ReleaseGateDecision], [OC-4 FindingAnnotation]

Technical Implementation Details (I6) [Informative]

Model and training profile [Informative]

model_id=devsecops-gate-text-model; temperature=0.0; max_tokens_out=800
 prompt_pack_id=devsecops-gates-v1 (threshold tables, exception policy, remediation templates)
 RAG: sources={policy catalog, exceptions registry, vuln advisories, prior gate decisions}; max_docs=12; min_similarity=0.78; citations required
 fine_tuning/adapters: none initially; evaluate on decision consistency and remediation quality
 guardrails: write only status checks and advisory comments unless allow_auto_fix=true

Memory and state [Informative]

working_memory.max_tokens=4k; eviction=recency_then_importance
 episodic_memory: per run_id journal (inputs, metrics, decision, waivers); ttl=365d
 semantic_memory: namespaces=["gate-policies","exceptions","remediation-templates"];
 embeddings=text-embedding-sec-v1; k=12
 durable_state_store: append-only ledger; snapshot each gate_version change
 consistency: at-least-once for OC-1; exactly-once per idempotency_key for

ReleaseGateDecision

idempotency: per Output Contracts

Decision and routing logic [Informative]

Metrics derived:

- $\text{coverage_ok} = (\text{coverage_pct} \geq \text{min_coverage})$
- $\text{sast_ok} = (\text{sast.high} == 0)$
- $\text{sca_ok} = (\text{sca.critical} == 0)$
- $\text{iac_ok} = (\text{iac.high} == 0)$
- $\text{image_ok} = (\text{image.critical} == 0)$
- $\text{secrets_ok} = (\text{secrets} == 0)$

Gate formulae:

- $\text{merge_block} = \text{not} (\text{coverage_ok} \text{ and } \text{sast_ok} \text{ and } \text{sca_ok} \text{ and } \text{iac_ok} \text{ and } \text{secrets_ok}) \text{ or policy_specific_merge_blocks}$
- $\text{release_block} = \text{merge_block} \text{ or } (\text{not image_ok}) \text{ or policy_specific_release_blocks}$
- $\text{overall_status} = \text{"PASS"} \text{ if } (\text{not merge_block} \text{ and } \text{not release_block}) \text{ else } (\text{"WARN"} \text{ if only advisory thresholds tripped}) \text{ else "FAIL"}$

Prioritization score:

- $\text{remediation_priority} = 0.35\textit{exploitability} + 0.25\textit{reachability} + 0.2\textit{fix_availability} + 0.2\textit{blast_radius}$

Routing:

- if FAIL → emit OC-1, set OC-2 failure, emit OC-3 BLOCK; else PASS → OC-2 success; OC-3 ALLOW.

Model Risk Management [Informative]

continuous_validation: daily; suites=[goldens, contradictory-signal sets, noisy SARIF]

thresholds: eval_pass_rate $\geq$ 99.0 percent → auto_HITL if below

red_team_cycle: monthly probes (e.g., downgraded severities, malformed SARIF)

rollback_policy: eval_drop $\geq$ 1.5 pp for 48 h → revert model_id; notify owners

Transparency and Audit Trail (Approver/Auditor UX) [Informative]

decision_rationale_template: constraints_applied, metrics snapshot, failing rules, why_it_matters, control_refs, suggested_fixes
UI/API: expose classification_label, provenance.attestation, decision_rationale_url
audit_log_format: JSONL, stable field order, retention per classification/legal_hold

Incident Response Integration [Informative]

If incident links to dependency or image class, enforce temporary stricter thresholds; auto-annotate related repos with required upgrades.

Change Impact Assessment [Informative]

Compute regression flags vs. previous run (gate_version, metrics deltas); block if regression exceeds tolerance.

Stakeholder Feedback Loop [Informative]

Capture maintainer labels={accepted_fix|false_positive|needs_exception}; feed governance-reviewed updates to policy catalog; never auto-train on regulated evidence.

Data Sovereignty and Legal Hold [Informative]

classification default C2; legal_hold=true freezes purge for OC snapshots and related evidence_refs.

Interfaces (links only) [Informative]

Consumes: CI/CD Events; SAST; SCA; IaC; Image Scan
Produces: OC-1 PipelineGateResult; OC-2 PRStatusCheck; OC-3 ReleaseGateDecision; OC-4 FindingAnnotation

Safety and abuse prevention [Informative]

kill_switch on abnormal block rate spikes; throttle comment volume; redact file paths that reveal secrets; deny writing to production repos without policy.

Testing and validation [Informative]

contract tests for OC-1..OC-4; replay historical runs; mutation tests (severity flips, missing artifacts); schema and signer checks.

Deployment and lifecycle [Informative]

scale on build concurrency; canary new gate_version; SBOM and SLSA attestations; sign all outputs; periodic threshold recalibration.

References / Standards [Informative]

Copyright © 2025 John M. Willis and Quantum Powered Security, Inc. • CC BY 4.0

MCP-Native Protocol Specification (I6) [Normative]

(Canonical schemas and validation live here; keep example payloads synchronized with the Agent Blueprint.)

- **Native Protocol(s) Consumed:** CI/CD Build Events; SAST (SARIF); SCA (CycloneDX+vuln); IaC Scan (Checkov/tfsec); Container Image Scan (Trivy/Anchore)
- **Native Protocol(s) Produced:** PipelineGateResult (events/REST); PRStatusCheck (Git APIs); ReleaseGateDecision (orchestrator APIs); FindingAnnotation (PR comments/events)
- **MCP Context Fields:**
 - **Required:** mission_id; role="DevSecOpsPipelineAgent"; intent="assure"; policy_refs=[SA-11, RA-5, CM-6, org pipeline policies]; constraints=[merge/release guardrails]; provenance.attestation (SPIFFE + KID)
 - **Optional:** classification; decision_basis; legal_hold
- **Enforcement Note:** Git and release PEPs MUST honor blocks; waivers require signed HITL token with scope and expiry.
- **Versioning and compatibility; producers/consumers registry:** authoritative in schema registry; see Schema Capsules for ranges/EOL.
- **Example payloads:** native and MCP-wrapped examples above are authoritative.
- **Transparency hooks:** classification_label, provenance.attestation, decision_rationale_url exposed to downstream UIs/APIs.

Conformance: This section is **[Normative]** and, together with each **Schema Capsule**, defines testable requirements.